

Universidade Aberta
Licenciatura em Engenharia Informática
Unidade Curricular 21184 — Projeto de Engenharia Informática
Ano Lectivo 2025/2026

ForensiQ

Plataforma Modular de Gestão de Prova Digital
para *First Responders*

Relatório Final (Fase 3)

Autor: João Rodrigues
N.º de aluno: 2203474
Orientador: Prof. Pedro Duarte Pestana
Data: 24 de Junho de 2026
Repositório: github.com/joao-pt/ForensiQ
Produção: forensiq.pt

Resumo

O ForensiQ é uma plataforma *web mobile-first* que digitaliza o registo, a preservação e a transferência de prova digital pelos agentes que primeiro chegam a uma cena de crime. O problema endereçado é a fragilidade da cadeia de custódia em ocorrências policiais com componente digital, hoje gerida por meios manuais (papel, fotografias no telemóvel pessoal, anotações dispersas). A solução assenta em três pilares: integridade verificável por *hash* SHA-256 encadeado, conforme ISO/IEC 27037:2012; um *ledger* de custódia *append-only* cujo estado legal é *derivado* da sequência de actos processuais (CPP art. 154.º, 158.º e 178.º); e demonstração assíncrona em produção em forensiq.pt, que dispensa configuração local pelo avaliador.

Este relatório final (Fase 3 da UC 21184) revê os Capítulos 1 (Introdução) e 2 (Desenho), completa o Capítulo 3 (Implementação) e acrescenta os Capítulos 4 (Testes) e 5 (Conclusões), reflectindo o sistema *tal como foi construído*. Desde o intercalar, a arquitectura evoluiu de forma documentada: a máquina de estados linear deu lugar a um *ledger* de eventos (ADR-0015), o modelo de duas funções a um modelo de seis funções com credencial e instituições (ADR-0017), e a identificação da prova passou a hierárquica (ADR-0016) — decisões registadas em dezanove ADRs. À data da entrega, o MVP está implementado e em produção, com uma *suíte* de **955 testes** de unidade/integração mais 38 testes *end-to-end*, conformidade demonstrada com a ISO/IEC 27037 e verificação externa automática da postura TLS e de cabeçalhos HTTP (Qualys SSL Labs A+, Mozilla HTTP Observatory A+, domínio incluído na lista HSTS *preload*). As limitações conhecidas — nomeadamente as alíneas c) e d) do RGPD Art. 32 e a dependência de controlo organizacional sobre o acesso DBA — estão honestamente documentadas e enquadradas como trabalho futuro.

Palavras-chave: cadeia de custódia digital; ISO/IEC 27037; SHA-256; *ledger* append-only; prova digital; Django; *first responder*; RGPD.

Índice

Lista de Acrónimos	5
1 Introdução	7
1.1 Descrição do projecto	7
1.2 Âmbito e enquadramento	8
1.3 Estado da arte e trabalho relacionado	8
1.4 Necessidades identificadas	9
1.5 Objectivos	10
1.6 Restrições	11
1.7 Resultados esperados	11
1.8 Evolução face ao intercalar	11
2 Desenho	13
2.1 Visão geral da solução	13
2.2 Arquitectura	13
2.2.1 Diagrama C4 nível 1 — Contexto	13
2.2.2 Diagrama C4 nível 2 — Contentores	15
2.2.3 Stack tecnológica	15
2.2.4 Modelo de dados	16
2.2.5 Decisões de arquitectura	18
2.3 O <i>ledger</i> de custódia e a derivação do estado legal	19
2.3.1 Eventos, custódios e génese	19
2.3.2 Estado legal derivado	20
2.3.3 Guardas de transição	20
2.4 Algoritmo de certificação e integridade	20
2.4.1 Modelo de ameaças e escolha do <i>hash</i>	20
2.4.2 Hash de integridade da evidência	21
2.4.3 Cadeia de custódia com <i>hash</i> encadeado (hv4)	21
2.4.4 Sequência canónica, concorrência e atomicidade	22
2.4.5 Imutabilidade em três camadas	22
2.5 Segurança transversal	23
2.5.1 Autenticação JWT em <i>cookies</i> HttpOnly	23
2.5.2 Autorização: papéis, credencial e <i>need-to-know</i>	24
2.5.3 Cabeçalhos HTTP de segurança	24
2.6 Conformidade ISO/IEC 27037 e RGPD Art. 32	24
2.6.1 Mapeamento à norma ISO/IEC 27037:2012	24
2.6.2 Conformidade com o RGPD Art. 32 e evidência externa	25
2.7 Interface do utilizador	25
3 Implementação	28
3.1 Decomposição do trabalho	28
3.2 Estado final por componente	29

3.3	Mecanismos centrais de integridade e custódia	30
3.4	Cumprimento dos critérios de aceitação	35
3.5	Desvios ao plano e evolução de âmbito	36
3.6	Demonstração em produção	37
4	Testes	40
4.1	Estratégia e camadas	40
4.2	Dimensão e distribuição da <i>suite</i>	40
4.3	Verificação dos critérios de aceitação	41
4.4	Exemplos de funcionamento normal	41
4.5	Testes de segurança	46
4.6	Testes E2E, acessibilidade e rapidez	46
4.7	Cobertura e integração contínua	46
5	Conclusões	47
5.1	Resultados face aos objectivos	47
5.2	Dificuldades e limitações	47
5.3	Trabalho futuro	48
5.4	Reflexão final	49
	Uso de IA generativa	49
A	Matriz de conformidade ISO/IEC 27037:2012	50
B	Verificações externas de postura TLS e de cabeçalhos HTTP	52
C	Exemplo do guia de transporte em PDF	53

Lista de Figuras

1	Diagrama C4 nível 1 — Contexto	14
2	Diagrama C4 nível 2 — Contentores	15
3	Modelo de dados — núcleo de prova e custódia (<i>ledger</i>).	17
4	Modelo de dados — acesso (RBAC), instituições e transporte da prova. . . .	17
5	Modelo de dados — taxonomia de crimes e prioridade por política criminal. .	17
6	Fluxograma do cálculo do <i>hash</i> encadeado e da detecção de adulteração. . . .	22
7	Defesa em profundidade contra adulteração: ORM, DRF e <i>triggers</i> PostgreSQL. 23	
8	Interface <i>mobile-first</i> num ecrã estreito	26
9	<i>Timeline</i> da cadeia de custódia de um item (<i>ledger</i>)	27
10	Modal de acto certificado (despacho de perícia)	27
11	Lista de ocorrências em modo tabela densa	38
12	Registo de prova no terreno (F2)	39
13	Autenticação (F1): ecrã de <i>login</i>	42
14	Painel do agente (F1): vista pós-autenticação do primeiro interveniente . . .	42
15	Ficha digital da evidência (F2/F4)	43
16	Verificação de integridade (F6)	44
17	Painel de estatísticas (RF08/RF12)	45
18	Vista <code>/reports/</code> de exportação de guias	53
19	Guia de transporte em PDF gerada pela aplicação (remessa GT-2026-0004) .	54

Lista de Tabelas

1	Objectivos específicos F1–F6 do MVP e respectivos critérios de aceitação observáveis.	11
2	Calendário das 16 semanas, com o conteúdo efectivamente executado e marcos formais.	12
3	Pilha tecnológica do ForensiQ com justificação por camada.	16
4	Síntese dos dezanove ADRs; detalhe em <code>docs/architecture/adr/</code>	19
5	Mapeamento sintético da ISO/IEC 27037:2012 aos mecanismos do ForensiQ. .	25
6	Decomposição de tarefas com precedências (Fase A: T1–T10; Fase B: T11–T19). 29	
7	Estado por componente na versão final.	30
8	Cumprimento dos requisitos funcionais e não-funcionais (versão final).	36
9	Distribuição (parcial) dos métodos de teste da <i>suíte</i>	41
10	Balanço quantitativo do ForensiQ à data da entrega final.	48
11	Matriz de rastreabilidade ISO/IEC 27037:2012	52
12	Resultados das auditorias externas de segurança (18 abr 2026); PDFs originais em <code>docs/compliance/external-tests/</code>	52

Lista de Acrónimos

ADR	<i>Architecture Decision Record</i>
API	<i>Application Programming Interface</i>
CIA-R	Confidentiality, Integrity, Availability, Resilience
CPP	Código de Processo Penal (português)
CSP	<i>Content Security Policy</i>
CSRF	<i>Cross-Site Request Forgery</i>
DAST	<i>Dynamic Application Security Testing</i>
DRF	Django REST Framework
E2E	<i>End-to-End</i> (teste de ponta a ponta)
ENFSI	<i>European Network of Forensic Science Institutes</i>
GPS	<i>Global Positioning System</i>
HSTS	<i>HTTP Strict Transport Security</i>
IDOR	<i>Insecure Direct Object Reference</i>
IMEI	<i>International Mobile Equipment Identity</i>
IMSI	<i>International Mobile Subscriber Identity</i>
ISO/IEC	<i>International Organization for Standardization / International Electrotechnical Commission</i>
JWT	<i>JSON Web Token</i>
MAC	<i>Media Access Control</i>
MP	Ministério Público
MVP	<i>Minimum Viable Product</i>
NIST	<i>National Institute of Standards and Technology</i>
NTP	<i>Network Time Protocol</i>
NUIPC	Número Único de Identificação de Processo-Crime
OPC	Órgão de Polícia Criminal
OWASP	<i>Open Web Application Security Project</i>
PITR	<i>Point-In-Time Recovery</i>
PII	<i>Personally Identifiable Information</i>
PSP	Polícia de Segurança Pública
PWA	<i>Progressive Web App</i>
RBAC	<i>Role-Based Access Control</i>
RF	Requisito Funcional
RGPD	Regulamento Geral sobre a Protecção de Dados (UE 2016/679)
RNF	Requisito Não-Funcional
RPO/RTO	<i>Recovery Point/Time Objective</i>
SAST	<i>Static Application Security Testing</i>
SCA	<i>Software Composition Analysis</i>
SHA	<i>Secure Hash Algorithm</i>
SLA	<i>Service Level Agreement</i>
SRI	<i>Subresource Integrity</i>
STRIDE	<i>Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service,</i>

	<i>Elevation of Privilege</i>
TLS	<i>Transport Layer Security</i>
TSA	<i>Time-Stamping Authority</i> (RFC 3161)
UAb	Universidade Aberta
UC	Unidade Curricular
VIN	<i>Vehicle Identification Number</i>
WCAG	<i>Web Content Accessibility Guidelines</i>
WSGI	<i>Web Server Gateway Interface</i>

1 Introdução

O ForensiQ é uma aplicação *web mobile-first* que digitaliza e padroniza o registo, a preservação e a transferência de prova digital pelos agentes que primeiro chegam a uma cena de crime. Este relatório final apresenta o estado do projecto à data de 24 de Junho de 2026, em cumprimento do calendário da Unidade Curricular 21184 da Universidade Aberta. O documento está estruturado em cinco capítulos, conforme o Guia de Projecto do orientador: introdução (presente capítulo), desenho (Capítulo 2), implementação (Capítulo 3), testes (Capítulo 4) e conclusões (Capítulo 5).

Relativamente ao relatório intercalar (Fase 2, 6 mai 2026), os Capítulos 1 e 2 são versões revistas e o Capítulo 3 é completado; os Capítulos 4 e 5 são novos. A arquitectura sofreu, entretanto, uma evolução significativa e documentada — abordada em detalhe em §1.8 e no Capítulo 2 — pelo que este relatório descreve o sistema *tal como foi construído*, não como estava planeado, conforme orientação do Guia (Pestana, 2026).

1.1 Descrição do projecto

Os agentes da Polícia de Segurança Pública (PSP) que actuam como *first responders* em ocorrências com componente digital recorrem hoje a métodos manuais para registar e preservar a prova: papel, fotografias avulsas no telemóvel pessoal, anotações manuscritas e etiquetas em saquetas. O processo é vulnerável em várias dimensões. A cadeia de custódia torna-se frágil: não existe registo verificável de quem manuseou a prova, em que momento e em que condições. A prova carece frequentemente de localização exacta da apreensão e de *timestamp* sincronizado. As práticas variam entre agentes e entre divisões, o que dificulta auditoria processual posterior. Em tribunal, fragilidades de cadeia de custódia podem inviabilizar prova relevante, com consequências para a justiça material (Casey, 2011; Association of Chief Police Officers, 2012).

O autor identificou o problema a partir da experiência directa enquanto agente da PSP e perito digital forense. O tema foi formalizado como auto-proposta na fase preliminar de selecção do tema, em alinhamento com o Projeto #38 (Pestana, 2025) da licenciatura, com a delimitação explícita de que o ForensiQ não realiza aquisição de prova — apenas a sua *gestão* e *controlo* após apreensão.

A solução é uma plataforma *web* servida pelo *backend* Django, acedida por *browser* a partir de *smartphone* ou computador, sem necessidade de instalação de *software* especializado. Os registos são imutáveis por desenho, com integridade verificável por terceiros através de *hash* SHA-256 (resumo criptográfico de tamanho fixo), e a cadeia de custódia é um *ledger* — registo cronológico *append-only* (só-de-acrécimo), à semelhança de um livro-razão, em que cada entrada referencia a anterior — de eventos encadeado criptograficamente, de modo a que qualquer adulteração posterior seja detectável por um terceiro independente. Esta detecção pressupõe o controlo de acesso ao motor da base de dados — premissa organizacional analisada em §2.4.1.

1.2 Âmbito e enquadramento

O âmbito do ForensiQ cobre o ciclo completo *registo* → *preservação* → *transferência* da prova após apreensão. A versão actual é *digital-only*, conforme registado no ADR-0010, com a estrutura preparada para módulos forenses adicionais (biológico, químico, físico) em trabalho futuro, ao abrigo da arquitectura modular do ADR-0006 e do requisito RF16 (estrutura documentada, não implementada). Estão fora do âmbito, de forma explícita: a aquisição forense de imagens de discos e telemóveis (*carving*, *dd*, FTK Imager); a análise de *malware*; a peritagem de ADN ou AFIS; a integração com sistemas internos da PSP, que requereria autorizações não disponíveis em contexto académico; e o uso de dados reais de processos judiciais, por questões legais e de confidencialidade.

1.3 Estado da arte e trabalho relacionado

O ecossistema da forense digital é hoje dominado por ferramentas maduras cujo objectivo central é a *aquisição* e a *análise* do conteúdo de dispositivos. A literatura e as boas práticas de referência — da obra seminal de Casey (2011) aos guias operacionais (Association of Chief Police Officers, 2012; Kent et al., 2006) e à norma ISO/IEC 27037:2012 (ISO/IEC, 2012) — estabelecem que a admissibilidade da prova digital depende de uma cadeia de custódia íntegra e documentada. Importa, porém, distinguir dois planos frequentemente confundidos: o do *conteúdo* (a imagem forense, os artefactos extraídos e a sua integridade criptográfica) e o plano *administrativo-legal* do bem apreendido (quem o detém, quando, onde e que transferências de posse ocorreram). O ForensiQ inscreve-se exclusivamente neste segundo plano, a jusante da aquisição.

No domínio da aquisição móvel, o **Cellebrite UFED** (*Universal Forensic Extraction Device*) é a referência de mercado, realizando extracções lógicas, de sistema de ficheiros e físicas de dispositivos iOS e Android, com descodificação de dados de aplicações e recuperação de conteúdo apagado — sempre sujeita aos limites impostos pelo *hardware* de segurança moderno. O **Magnet AXIOM** alarga o âmbito a uma lógica multi-fonte, consolidando num único ficheiro de caso prova proveniente de dispositivos móveis, computadores, serviços de *cloud* e veículos. No plano da análise de disco, o **Exterro FTK** (*Forensic Toolkit*), herdeiro da AccessData, oferece imagem de disco, indexação e reconstrução da actividade do utilizador; e o **Autopsy**, interface gráfica do *The Sleuth Kit*, disponibiliza, em regime *open-source*, análise de *timeline* e filtragem por *hash*, com uma arquitectura extensível por *plug-ins* em Java (ou Python via Jython). Todas asseguram a integridade do *conteúdo* adquirido por valores de *hash* e documentam a cadeia de custódia do *próprio acto de aquisição*.

Reconhece-se, com honestidade, que estas ferramentas não são alheias à problemática da custódia. As suas funcionalidades de *case management* e de *audit log* organizam achados de exame, registam acessos e produzem relatórios defensáveis; e existe uma categoria autónoma de sistemas de gestão de prova digital (*Digital Evidence Management Systems*, DEMS) — de que o Cellebrite Guardian é exemplo — vocacionada para centralizar a prova desde a apreensão até ao tribunal, mantendo registo de quem acedeu, partilhou ou modificou cada artefacto. As boas práticas europeias de referência reforçam, aliás, a necessidade de rastreabilidade integral

ao longo de todo o ciclo (European Network of Forensic Science Institutes, 2015).

Subsiste, todavia, uma diferença de *modelo* que delimita o contributo do ForensiQ. Primeiro, o foco: as ferramentas dominantes tratam o *workflow* de custódia física pós-apreensão — a sequência de transferências de posse entre agentes, instituições e locais — como metadado acessório do exame, e não como a entidade de primeira classe do sistema. Segundo, a garantia: o registo de auditoria, quando existe, é tipicamente um *log* aplicativo, mutável na prática e dependente da boa-fé operacional, e não um registo *append-only* imposto ao nível da própria base de dados, encadeado criptograficamente e assumido como fonte única de verdade. Terceiro, e decisivo, o estado: nenhuma destas soluções *deriva* automaticamente o estado legal do processo a partir desse registo imutável — o estado é, quando muito, um campo editável, sujeito a inconsistência.

É neste interstício que o ForensiQ se posiciona. Ao tratar cada movimento de custódia como um registo *append-only* imutável (garantido por *triggers* ao nível do motor PostgreSQL), ao reconstruir o estado legal por derivação determinística sobre esse registo, e ao colocar o fluxo de transferências no centro do modelo de dados, o ForensiQ não concorre com o Cellebrite, o Magnet, o FTK ou o Autopsy: complementa-os. Ocupa o espaço organizacional que medeia entre a apreensão do dispositivo e a sua entrega para aquisição e análise — plano em que as ferramentas dominantes, por desenho, não actuam. O contributo é, assim, de âmbito e não de substituição: dar garantias formais de integridade e rastreabilidade ao processo de custódia, em coerência com os princípios consagrados pela literatura e pelas normas de referência (Casey, 2011; ISO/IEC, 2012; Association of Chief Police Officers, 2012).

1.4 Necessidades identificadas

A análise do contexto operacional, validada com o orientador na proposta de Fase 1, identificou três necessidades transversais que estruturam todo o desenho da solução:

1. **Integridade verificável.** Qualquer alteração posterior a um registo de prova tem de ser detectável por um terceiro que tenha acesso ao identificador e aos campos públicos. Esta necessidade liga-se directamente ao §5.4.5 (preservação da integridade) da norma ISO/IEC 27037:2012 (ISO/IEC, 2012).
2. **Rastreabilidade auditável.** Cada manuseamento da prova — quem, quando, em que estado — tem de ficar registado de forma imutável, com sequência canónica que sobreviva a discrepâncias de relógio entre máquinas. Esta necessidade materializa o §6.1 (cadeia de custódia) da norma.
3. **Utilidade no terreno.** O instrumento tem de funcionar num *smartphone*, com uma só mão, em redes móveis variáveis, sem instalação prévia de *software* especializado nem formação técnica avançada. Uma plataforma robusta mas inutilizável no momento da apreensão não resolve o problema.

A estas três necessidades técnicas acrescem requisitos legais e éticos não-negociáveis: cumprimento do RGPD, em particular do Artigo 32.^a (Parlamento Europeu e Conselho da União Europeia, 2016), conformidade processual com o Código de Processo Penal (apreensão,

validação e perícia) e ausência de exposição de dados pessoais em ambiente *open-source*.

1.5 Objectivos

Objectivo geral. Desenvolver uma plataforma *web mobile-first* que digitalize a recolha, preservação e transferência de prova digital pelos *first responders* da PSP, com integridade verificável conforme a norma ISO/IEC 27037:2012, e que seja demonstrável num *smartphone* em condições reais.

Objectivos específicos. Os seis objectivos específicos da proposta correspondem às funcionalidades F1–F6 do MVP, com critérios de aceitação observáveis (Tabela 1). O cumprimento de cada um é confrontado com a evidência empírica no Capítulo 3 (§3.4) e no Capítulo 4. Dois destes objectivos evoluíram desde a proposta, de forma documentada: F3 (custódia) passou de uma máquina de estados linear para um *ledger* de eventos com estado legal derivado (ADR-0015), mais fiel ao processo penal; e F4 (ficha de dispositivo) foi *subsumido* pela própria evidência — o modelo **DigitalDevice** foi removido e os seus atributos passaram a viver em **Evidence** com a taxonomia *digital-first* (ADR-0010).

Obj.	Funcionalidade	Critério de aceitação observável
F1	Autenticação JWT com funções distintas	<i>Login</i> válido em <2 s; funções com permissões verificáveis; erro 401 sem fuga de informação interna.
F2	Registo de prova com fotografia e GPS	Criação completa em <30 s no <i>smartphone</i> ; identificador único, <i>timestamp</i> do servidor, <i>hash</i> SHA-256 dos metadados e dos <i>bytes</i> da fotografia.
F3	Cadeia de custódia imutável (<i>ledger</i>)	Eventos <i>append-only</i> sem UPDATE nem DELETE; génese obrigatória; estado legal derivado da sequência; sem retrocesso após terminal; alteração directa na base de dados detectável por <i>hash</i> encadeado.
F4	Ficha digital da evidência	Atributos técnicos (tipo, marca, modelo, estado, série, IMEI/VIN) associados à evidência via taxonomia <i>digital-first</i> e type_specific_data .
F5	API REST documentada	<i>Endpoints</i> testáveis via OpenAPI/Swagger UI gerado automaticamente.
F6	Exportação de relatório em PDF	Documento com os registos e o histórico de custódia, como guia de transporte com QR de verificação (ADR-0012).

Obj.	Funcionalidade	Critério de aceitação observável
------	----------------	----------------------------------

Tabela 1: Objectivos específicos F1–F6 do MVP e respectivos critérios de aceitação observáveis.

1.6 Restrições

A execução do projecto está sujeita a quatro restrições: duração de 16 semanas com três marcos eliminatórios fixos (proposta, intercalar, final); trabalho estritamente individual sem possibilidade de divisão de tarefas; dependência de planos gratuitos da Neon (PostgreSQL gerido) e da Fly.io (alojamento Frankfurt) durante o desenvolvimento; e indisponibilidade de orçamento para serviços comerciais, *e.g.* APIs pagas de OCR ou OSINT. A estas restrições acrescem condicionantes éticas: o sistema é desenhado para uso futuro com dados reais, mas é demonstrado exclusivamente com dados sintéticos gerados por *seed*; o repositório é público no GitHub e segue o princípio de “segurança por desenho, transparência por omissão”.

1.7 Resultados esperados

A verificação do cumprimento dos objectivos é tripla: pelo funcionamento da aplicação em produção em forensiq.pt, pelos testes automatizados no repositório (Capítulo 4) e pela verificação externa automática da postura de transporte (TLS) e de cabeçalhos HTTP. A aplicação em produção permite a um avaliador externo executar os fluxos críticos — criação de ocorrência, registo de evidência com GPS e fotografia, actos de custódia, exportação de PDF — sem necessidade de configurar ambiente local. As três verificações externas automáticas em `docs/compliance/external-tests/` (HSTS *Preload*; Mozilla HTTP Observatory A+; Qualys SSL Labs A+) avaliam a postura criptográfica (TLS) e os cabeçalhos HTTP — uma dimensão específica, que não substitui uma auditoria de segurança aplicacional (*DAST/pentest*).

1.8 Evolução face ao intercalar

O relatório intercalar identificou honestamente duas fragilidades de modelo e calendarizou a sua correcção para a fase final. Ambas foram resolvidas, e a resolução motivou um *refactor* de fundo (“Fase 2/3”), documentado nos ADRs 0014 a 0019 e no `changelog.md`:

1. A **máquina de estados linear** de custódia não acomodava cenários reais (devolução directa por ordem do MP, múltiplas perícias, movimentação não-linear). Foi substituída por um **ledger de eventos** *append-only* cujo estado legal é *derivado* da sequência (ADR-0015), alinhado com o CPP (art. 154.º, 158.º, 178.º).
2. O **conflito CSP nível 3 com o Leaflet** foi resolvido de forma cirúrgica, preservando a postura de segurança (§2.5.3).

Acrescem três evoluções de âmbito, bem-vindas porque o núcleo estava sólido (Guia §6): identificação **hierárquica** da prova com sub-componentes (ADR-0016); modelo de acesso de **seis funções** com credencial nacional e instituições (ADR-0017); e **actos certificados** de autoridade (validação da apreensão e despacho de perícia) com identidade estruturada

no *ledger* (ADR-0017, *hash* v4). A Tabela 2 apresenta o calendário das 16 semanas com o conteúdo efectivamente executado; os desvios são analisados em §3.5.

Sem.	Datas	Conteúdo executado	Marco
1–2	17–28 mar	Proposta inicial, configuração do repositório.	Proposta (25 mar)
3–4	31 mar–11 abr	MoSCoW, consolidação dos ADRs 0001–0005 (iniciados na Sem. 1–2), modelo ER, primeiros <i>models</i> Django.	
5–6	14–25 abr	Autenticação JWT em <i>cookies</i> HttpOnly (ADR-0009), CSP <i>nonce</i> , F2 e F3 funcionais.	
7	28 abr–2 mai	<i>Triggers</i> PostgreSQL; consolidação dos ADRs 0006–0010 (decididos nas semanas anteriores); auditorias internas (segurança, <i>design</i> , taxonomia). <i>Demo interna síncrona não realizada nesta janela</i> (§3.5).	Demo interna
8	5–6 mai	Submissão do relatório intercalar.	Intercalar (6 mai)
9–10	7–16 mai	Reforço de cobertura de testes; <i>hardening</i> de segurança (auditoria delta 18 mai); onda Dependabot.	
11–12	19–30 mai	<i>Refactor</i> de fundo: <i>ledger</i> de custódia (ADR-0015), IDs hierárquicos (ADR-0016), taxonomia de crimes (ADR-0014), QR + verificação pública (ADR-0012).	
13	2–8 jun	Papéis/instituições (ADR-0017), catálogo de tipos (ADR-0018), política numa fonte única (ADR-0019); <i>rebuild</i> do frontend (HTMX).	
14	9–13 jun	Consolidação “fonte única”; actos certificados (validação, despacho); subequipamentos; redesign do painel; revisões adversariais.	
15	16–20 jun	Reunião de preparação para defesa; ensaio de perguntas de júri; revisão final do relatório.	Prep. defesa
16	24 jun	Submissão do relatório final e do código.	Final (24 jun)

Tabela 2: Calendário das 16 semanas, com o conteúdo efectivamente executado e marcos formais.

2 Desenho

Este capítulo apresenta a concepção do ForensiQ *tal como foi construída*, organizada do nível mais agregado para o mais detalhado. A Secção 2.1 introduz a fronteira do sistema e os seus actores; §2.2 descreve a arquitectura segundo o modelo C4 (Brown, 2014) e sumariza os dezanove ADRs; §2.3 é o núcleo de domínio — o *ledger* de custódia e a derivação do estado legal; §2.4 detalha a integridade por *hash*; §2.5 aborda a segurança transversal; §2.6 apresenta a conformidade com a ISO/IEC 27037 e o RGPD Art. 32; §2.7 fecha com a *interface*. Cada afirmação técnica é ancorada num módulo ou caminho verificável no repositório.

2.1 Visão geral da solução

ForensiQ é uma aplicação *web* servida pelo Django, acedida via *browser* a partir de *smartphone* ou computador. O modelo de acesso, revisto no ADR-0017, assenta em **dois eixos ortogonais**: a *função* (`User.profile`) e a *credencial* (`User.clearance`).

Existem seis funções (`src/backend/core/models.py`, `User.Profile`): `FIRST_RESPONDER` (agente de OPC no terreno — cria ocorrências e regista a apreensão), `FORENSIC_EXPERT` (perito — recebe a prova no laboratório e conduz a perícia), `EVIDENCE_CUSTODIAN` (custódio/fiel depositário — armazena e movimenta), `CASE_AUTHORITY` (autoridade judiciária, Ministério Público — pratica os actos certificados de validação da apreensão e despacho de perícia), e duas funções *só-leitura*: `CHEFE_SERVICO` e `AUDITOR`. A credencial `NACIONAL` confere leitura de toda a prova nacional, por oposição à credencial `NORMAL` (acesso *need-to-know*, restrito aos itens em cujo *ledger* o utilizador ou a sua instituição participam). O perfil de *staff* do Django mantém-se para administração.

A solução tem como sistemas externos: a *Geolocation API* do *browser* (captura de GPS no momento da apreensão); o OpenStreetMap, via proxy servidor, para geocodificação inversa (Nominatim) e pontos de interesse próximos (Overpass); o serviço imeidb.xyz para enriquecimento opcional de fichas de telemóvel a partir do IMEI (com *cache*, ADR-0008); e o redireccionamento para o vindecoder.eu para VIN. O *frontend* é *server-rendered*: *templates* Django com fragmentos HTMX e Leaflet servido localmente, sem *build step* (a SPA de JavaScript por página do intercalar foi abandonada na Fase 2/3 — ADR-0004 *superseded*). A plataforma vive em produção em forensiq.pt, alojada em Fly.io Frankfurt com PostgreSQL gerido pela Neon na mesma região (ADR-0001 e ADR-0005).

2.2 Arquitectura

2.2.1 Diagrama C4 nível 1 — Contexto

A Figura 1 apresenta o sistema, os seus seis tipos de utilizador e os sistemas externos, segundo o nível 1 do modelo C4 (Brown, 2014, 2024). O diagrama foi actualizado para o estado pós-refactor; o fonte está em `docs/architecture/diagrams/c4-context (.mmd/.dot)`.

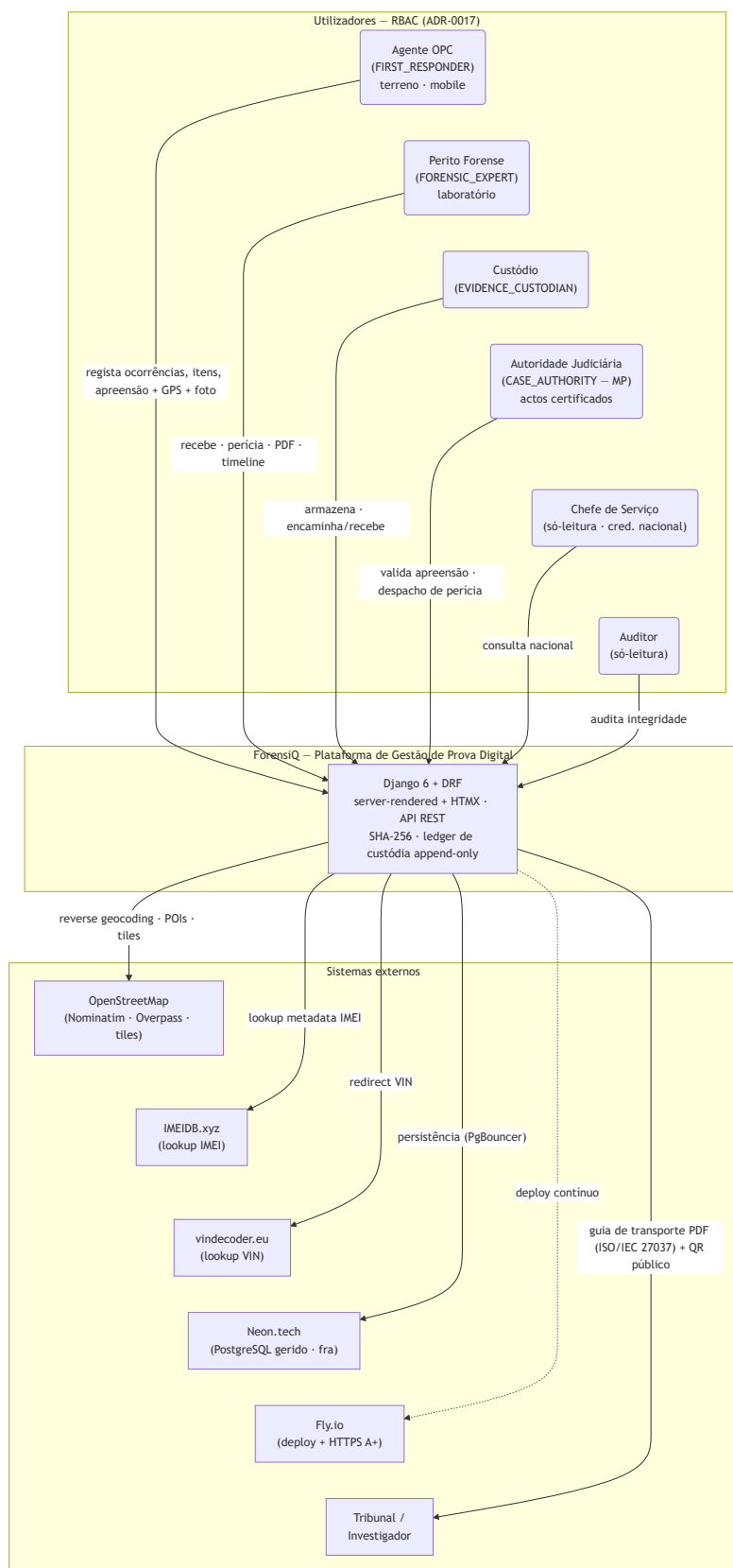


Figura 1: Diagrama C4 nível 1: ForensiQ, as seis funções de utilizador e os sistemas externos.

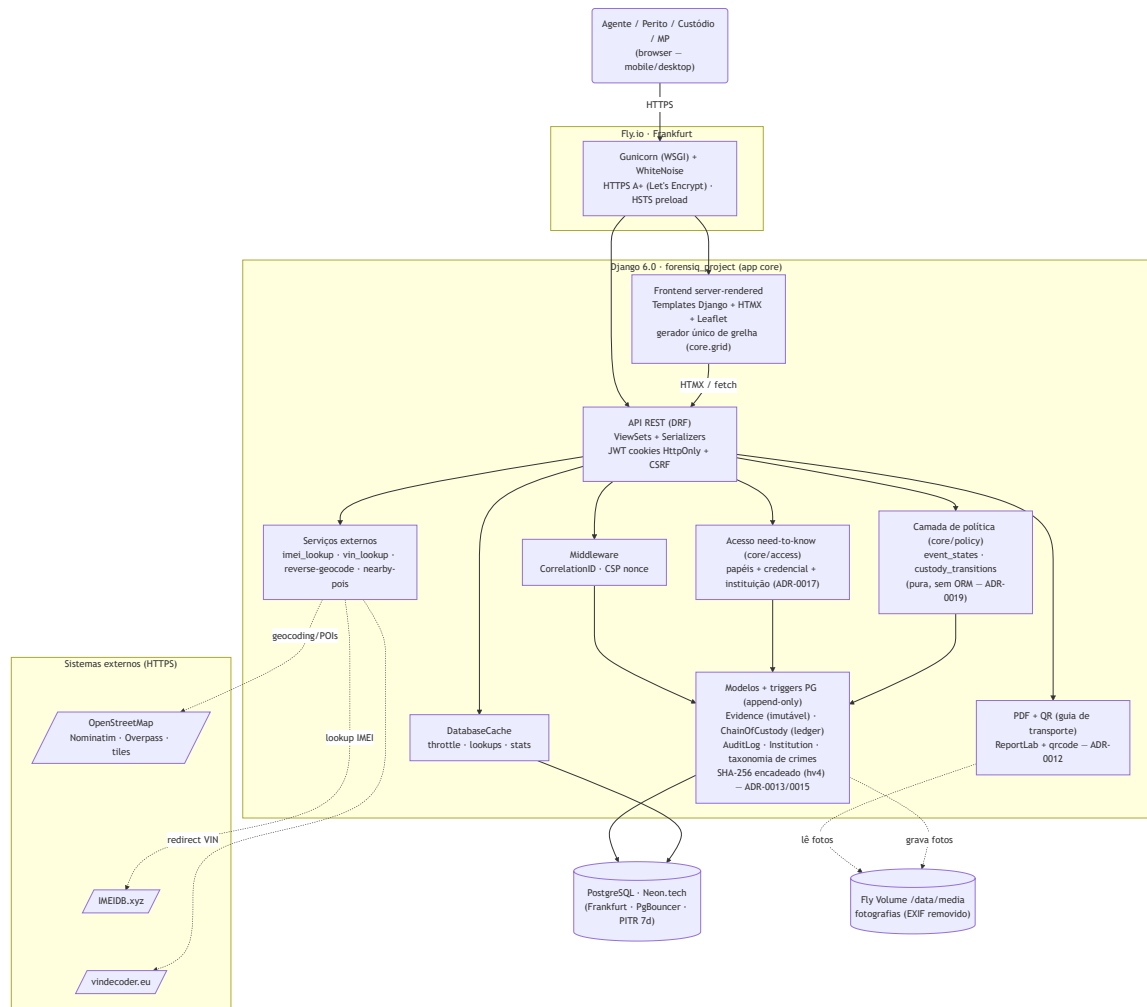


Figura 2: Diagrama C4 nível 2 (contentores) com tecnologias e a camada de política de domínio.

2.2.2 Diagrama C4 nível 2 — Contentores

A Figura 2 decompõe a aplicação. O *frontend server-rendered* (HTMX + Leaflet) e a API REST (DRF) são servidos pelo mesmo processo Django sobre Gunicorn/WhiteNoise; uma camada de *política de domínio* pura (*core/policy*) concentra as regras processuais (ADR-0019); os modelos *append-only* persistem em PostgreSQL (Neon) com *triggers* de imutabilidade; as fotografias residem num volume persistente da Fly.io.

2.2.3 Stack tecnológica

A Tabela 3 resume a *stack* adoptada e a justificação de cada escolha; o detalhe de fundo está nos ADRs.

Camada	Tecnologia	Motivo da escolha (ADR)
<i>Backend web</i>	Django 6.0.6 + DRF 3.17	ORM maduro, <i>admin</i> integrado, autenticação <i>built-in</i> ; <i>ecosystem</i> convencional e defensável (ADR-0002, ADR-0003, ADR-0011).
Documentação OpenAPI	drf-spectacular 0.29	Swagger UI gerado a partir dos <i>viewsets</i> (RF05).
Autenticação	SimpleJWT 5.5 + cookies HttpOnly	JWT <i>stateless</i> ; transporte em <i>cookies</i> mitiga XSS (ADR-0009).
Validação de imagens	Pillow 12.2	Validação MIME e remoção de metadados EXIF no <i>upload</i> .
Geração de PDF + QR	ReportLab 4.5 + qrcode 8	Guia de transporte com QR de verificação (ADR-0012).
Cliente HTTP <i>server-side</i>	httpx 0.27	Consulta/enriquecimento (<i>lookup</i>) de IMEI (ADR-0008).
Filtragem	django-filter 24	Filtros declarativos por <i>viewset</i> .
Base de dados	PostgreSQL via Neon.tech	<i>Triggers</i> de imutabilidade; PITR 7 dias (<i>disaster-recovery</i>); integridade referencial (ADR-0001).
<i>Frontend</i>	Templates Django + HTMX + Leaflet	<i>Server-rendered</i> , sem <i>build step</i> ; <i>mobile-first</i> ; estado derivado consumido directamente do <i>backend</i> (ADR-0004 rev.).
Mapa	Leaflet 1.9 + OpenStreetMap	Sem chave de API; servido localmente (mesma origem) e Referrer-Policy (ADR-0007).
Alojamento	Fly.io fra + Gunicorn 26 + WhiteNoise 6	Frankfurt (perto da Neon); HTTPS automático; volume persistente (ADR-0005).

Tabela 3: Pilha tecnológica do ForensiQ com justificação por camada.

2.2.4 Modelo de dados

O modelo entidade-relação é apresentado em três vistas ligadas, por área, para garantir legibilidade (a versão integral em alta resolução está em docs/architecture/diagrams/er-forensiq.png). Face ao intercalar, há três mudanças estruturais: (i) o modelo `DigitalDevice` foi **removido** e subsumido por `Evidence + type_specific_data` (ADR-0010); (ii) surgiram as entidades de **instituição** (`Institution`,

InstitutionMembership) e de **transporte** (Portador, ProvaEmTransito), para o modelo de custódia institucional em dois tempos (ADR-0016/0017); *(iii)* surgiu a **taxonomia de crimes** em três níveis com prioridade por política criminal (ADR-0014).

A Figura 3 apresenta o núcleo de prova e custódia (Occurrence, Evidence com sub-componentes, o ledger ChainOfCustody e o AuditLog). A Figura 4 apresenta o eixo de acesso e a custódia institucional (User, Institution e o transporte em dois tempos). A Figura 5 apresenta a taxonomia de crimes. As três vistas ligam-se pelas chaves estrangeiras assinaladas (“ver Fig...”).

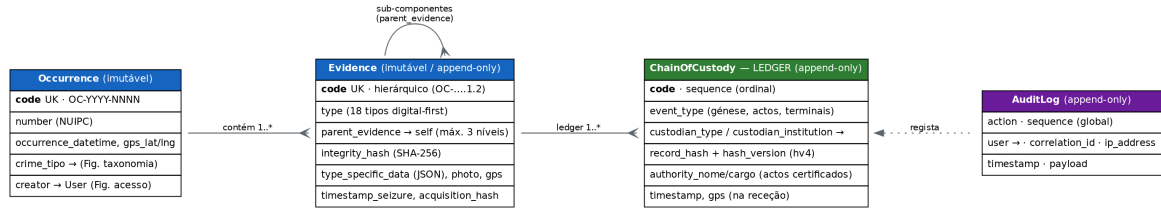


Figura 3: Modelo de dados — núcleo de prova e custódia (ledger).

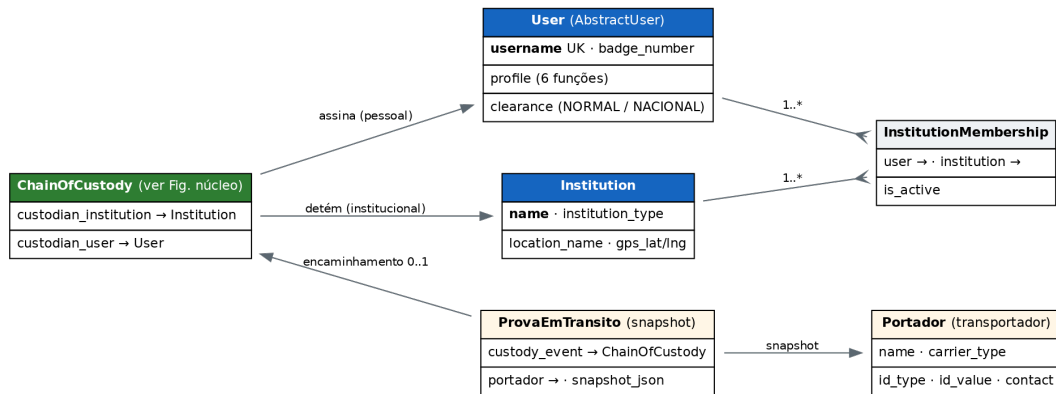


Figura 4: Modelo de dados — acesso (RBAC), instituições e transporte da prova.

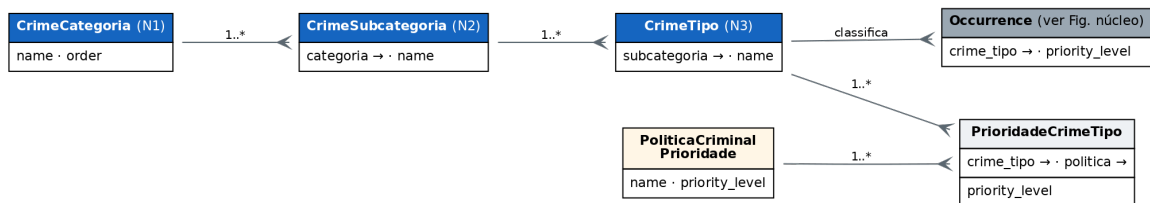


Figura 5: Modelo de dados — taxonomia de crimes e prioridade por política criminal.

User. AbstractUser estendido com **profile** (seis funções), **clearance** (NORMAL/NACIONAL), **badge_number** e ligação *many-to-many* a instituições via **InstitutionMembership**. As permissões consultam ambos os eixos (§2.5.2).

Occurrence. Caso ou cena de crime, **imutável** após criação, com **number** (NUIPC), **code** auto-gerado (OC-YYYY-NNNN), **crime_tipo** (taxonomia), prioridade derivada, coordenadas GPS, **occurrence_datetime** e *foreign key* para o agente criador.

Evidence. Item apreendido, **imutável**, com taxonomia de 18 tipos digital-first (ADR-0010) e relação `parent_evidence` para hierarquia até três níveis (`MAX_TREE_DEPTH=3`). O código é **hierárquico e derivado da ocorrência** (ADR-0016): um item-raiz é `0C-2026-0001.1`; um sub-componente, `0C-2026-0001.1.2`. Quatro tipos são terminais (não admitem sub-componentes): `SIM_CARD`, `MEMORY_CARD`, `RFID_NFC_CARD`, `DIGITAL_FILE`. Cada evidência tem `integrity_hash` SHA-256 que cobre os metadados e os *bytes* da fotografia (com EXIF removido), `type_specific_data` em `JSONField` (validadores de IMEI/Luhn, IMSI, MAC, VIN) e, para cópias de dados, `acquisition_hash` distinto do hash de integridade.

ChainOfCustody. *Ledger* de eventos *append-only* — o núcleo do projecto, detalhado em §2.3 e §2.4.

Institution / InstitutionMembership / Portador / ProvaEmTransito. A custódia é *institucional*: a instituição detém a prova, a pessoa assina (ADR-0017). A movimentação em dois tempos regista o transportador (**Portador**) como *snapshot* no evento de encaminhamento (**ProvaEmTransito**).

AuditLog. Registo transversal de operações sensíveis (acessos e exportações), imutável a *alterações* (*trigger BEFORE UPDATE*) mas *não* encadeado e purgável por retenção RGDPD configurável (`purge_audit_logs`); regista operações efectivas, não tentativas de adulteração recusadas. Inclui `sequence` global monótona, `correlation_id` (UUID por pedido), `ip_address` e `payload`.

2.2.5 Decisões de arquitectura

As decisões estruturantes foram registadas como ADRs versionados em `docs/architecture/adr/`. A Tabela 4 sumariza os dezanove ADRs em vigor; o ADR-0004 está integralmente *superseded* (mantido por rasto histórico) e, no ADR-0007, apenas a decisão de SRI foi *superseded* — a *Referrer-Policy* mantém-se em vigor. O detalhe completo, com alternativas rejeitadas, está nos ficheiros ADR.

ADR	Tema	Decisão
0001	PostgreSQL + Neon	Postgres com <i>triggers</i> de imutabilidade; Neon (fra), <i>connection pooling</i> .
0002	Estrutura Django + modelos	Django + DRF; User AbstractUser ; ledgers <i>append-only</i> .
0003	API REST	DRF <i>ModelViewSet</i> + <i>DefaultRouter</i> ; sem PUT/PATCH/DELETE nos ledgers.
0004	Frontend (<i>superseded</i>)	HTML/CSS/JS <i>vanilla</i> → revisto para <i>server-rendered</i> + HTMX.
0005	<i>Deployment</i>	Fly.io fra + Neon + Let's Encrypt.
0006	Extensibilidade modular	Camada de serviços; preparação para módulos forenses futuros.
0007	SRI e Referrer-Policy (<i>sup.</i>)	SRI SHA-512 nos recursos de CDN; strict-origin-when-cross-origin .
0008	<i>Cache de lookups</i>	<code>DatabaseCache</code> para IMEI (com TTL); VIN por redirect.

ADR	Tema	Decisão
0009	JWT em <i>cookies</i> HttpOnly	<i>Cookies</i> HttpOnly + Secure + SameSite; CSRF <i>double-submit</i> .
0010	Taxonomia de evidência	18 tipos digital-first; hierarquia 3 níveis; DigitalDevice removido.
0011	Upgrade Django 6	Migração CVE-driven para Django 6.0.x.
0012	PDF = guia de transporte	PDF não é prova autónoma; QR + <i>endpoint</i> público de verificação.
0013	GPS e fórmula de <i>hash</i>	GPS quantizado; <i>record_hash</i> encadeado com versão (hv2–hv4).
0014	Taxonomia de crimes	Três níveis + prioridade por política criminal.
0015	<i>Ledger</i> de custódia	Eventos <i>append-only</i> ; estado legal <i>derivado</i> (CPP 154/158/178).
0016	Identificação hierárquica	Código derivado da ocorrência; génese por proveniência; custódia v2.
0017	Papéis, credenciais, instituições	Seis funções + credencial nacional; acesso <i>need-to-know</i> ; actos certificados.
0018	Catálogo de tipos editável	EvidenceTypeRef em BD, fora do ledger imutável; <i>snapshot</i> no evento.
0019	Política numa fonte única	core/policy pura (sem ORM): vocabulário, guardas e derivação de estado.

Tabela 4: Síntese dos dezanove ADRs; detalhe em docs/architecture/adr/.

2.3 O *ledger* de custódia e a derivação do estado legal

A mudança arquitectural mais relevante desde o intercalar foi a substituição da máquina de estados linear por um ***ledger* de eventos** (ADR-0015). A motivação foi de *fidelidade ao processo*: a custódia real não é linear (há múltiplas perícias, encaminhamentos em ordem livre, devoluções directas por ordem do MP), e forçar essa realidade num autómato linear obrigava a registar passos fictícios — um anti-padrão de qualidade da prova reconhecido no próprio intercalar.

2.3.1 Eventos, custódios e génese

Cada item tem um *ledger* de eventos **ChainOfCustody** ordenados por **sequence**. Cada evento tem um **event_type** (o acto processual) e um **custodian_type** (quem detém a prova *após* o evento — eixo ortogonal). O vocabulário vive numa fonte única, **core/policy/event_states.py** (ADR-0019), importada pelos modelos — nunca o contrário. Os actos são:

- **Génese** (primeiro e único primeiro movimento, por proveniência): **APREENSAO_OBJETO** (objeto físico, CPP art. 178.^o), **APREENSAO_DADOS** (dados copiados no terreno para suporte autónomo, Lei do Cibercrime art. 16.^o) e **DERIVACAO_ITEM** (sub-componente autonomizado, que herda a base legal do pai).
- **Actos subsequentes**: **VALIDACAO_APREENSAO**, **DESPACHO_PERICIA**, **INICIO_PERICIA**, **CONCLUSAO_PERICIA**.

- **Movimentação em dois tempos** (ADR-0016 v2): `ENCAMINHAMENTO_CUSTODIA` (a origem entrega a prova a um portador — fica *em trânsito*, sem GPS) seguido de `RECEPCAO_CUSTODIA` (o destino confirma a chegada e ganha coordenadas).
- **Terminais** (fecham o *ledger*): `RESTITUICAO` e `DESTRUICAO`; mais `PERDA_FAVOR_ESTADO`.

2.3.2 Estado legal derivado

O estado legal **não é uma coluna** — é *derivado* da sequência de eventos pela função pura `derive_legal_state` (`core/policy/event_states.py`), fonte única das *strings* de estado em filtros, serializadores, estatísticas e CSS. Esta separação resolve um defeito sutil do modelo anterior: a etiqueta “apreensão validada” é um *acto* (não desloca a prova) e não deve desaparecer quando o item viaja — por isso a validação deriva-se num eixo próprio (`validation_status`), distinto do eixo de custódia/localização. Os estados de custódia derivados são: `a_guarda_opc`, `em_transito`, `encaminhada`, `em_pericia`, `pericia_concluida`, `restituida`, `perdida_favor_estado` e `destruida`.

2.3.3 Guardas de transição

As regras processuais que decidem que evento é válido a seguir são predicados puros em `core/policy/custody_transitions.py`, usados *tanto* pelo `clean()` do modelo (que recusa com a mensagem legal) *como* pelo frontend (que só oferece transições válidas) — o ecrã nunca pode contrariar o modelo. As guardas mais relevantes:

- **Génese única e coerente**: exactamente um evento de génese, na posição 1, do tipo determinado pela proveniência (objeto/dados/derivação).
- **Validação da apreensão** (CPP art. 178.º/6): só com apreensão prévia, e uma única vez; prazo legal de 72h (configurável) com *flag* `validation_overdue`.
- **Despacho de perícia exige apreensão validada**: invariante de qualidade do ForensiQ — mais estrito do que a jurisprudência, que admite a validação implícita — assente em CPP art. 178.º/6 (validação da apreensão) e art. 154.º (despacho que ordena a perícia); o modal único pode registar os dois actos em sequência.
- **Gate de laboratório** (CPP art. 154.º): entregar prova a um custódio de laboratório exige um `DESPACHO_PERICIA` prévio no *ledger*.
- **Terminal fecha o ledger**: após restituição/destruição, nenhum evento é aceite.

2.4 Algoritmo de certificação e integridade

A integridade da prova digital é o requisito mais crítico do ForensiQ.

2.4.1 Modelo de ameaças e escolha do *hash*

A análise seguiu o método STRIDE simplificado (Shostack, 2014). O sistema é de *instância única* (um só *deployment*, sem aquisição forense distribuída), mas **não** é *single-tenant* quanto aos dados: impõe isolamento por instituição (*need-to-know* inter-institucional via `custodian_institution`, ADR-0017). O modelo de ameaças considera,

por isso, não só o agente que tenta aceder a dados de outro agente (IDOR intra-institucional), mas também o *insider* de uma instituição que tente ver prova sob custódia de outra (IDOR inter-institucional) — vector mitigado ao nível do `get_queryset()` de cada *viewset* (`core/access.py: scope_evidences, scope_occurrences_institutional, can_view_evidence`) e exercitado pelos testes `AuthorizationIDORTest`. A definição operacional de *prova adulterada* é: qualquer registo cujo conjunto de campos canónicos não reproduza o *hash* declarado, ou cuja sequência de custódia não reproduza o encadeamento a partir da raiz. A detecção é por recálculo independente (ISO/IEC 27037 §5.4.5 e §6.1).

A função é SHA-256 sobre campos públicos, sem chave secreta (não-HMAC). O modelo presume, honestamente, que o controlo de acesso ao motor PostgreSQL — nomeadamente contas com `ALTER TABLE` — é organizacional e fica fora do âmbito da plataforma: um adversário com privilégios DBA poderia desactivar *triggers*, alterar registos e recomputar a cadeia internamente. A detecção desse cenário requer uma *âncora externa* anterior (cópia auditada, exportação assinada, ou selo TSA RFC 3161), identificada como trabalho futuro (§5.3). A escolha do SHA-256 (FIPS 180-4 (National Institute of Standards and Technology, 2015)) fundamenta-se em maturidade, adoção em boas práticas forenses (ENFSI (European Network of Forensic Science Institutes, 2015), ACPO (Association of Chief Police Officers, 2012)), interoperabilidade (`sha256sum/certutil`) e custo desprezável; alternativas como MD5 (Wang and Yu, 2005) e SHA-1 (Stevens et al., 2017) estão quebradas, e SHA-3 (Bertoni et al., 2011)/BLAKE (Aumasson et al., 2013) têm menos jurisprudência forense.

2.4.2 Hash de integridade da evidência

Cada evidência recebe, na criação, um *hash* SHA-256 determinístico que cobre os campos canónicos e os *bytes* da fotografia (reduzidos ao seu próprio *hash*, após remoção de EXIF, de modo a que o *hash* seja invariante a metadados mas detecte substituição dos *bytes* da imagem). O `type_specific_data` é serializado com `sort_keys=True`, garantindo representação canónica independente da ordem das chaves. O *hash* é gravado e nunca recalculado.

2.4.3 Cadeia de custódia com *hash* encadeado (hv4)

Cada evento do *ledger* tem um `record_hash` SHA-256 que inclui o *hash* do evento anterior — estrutura inspirada em *blockchain*, sem prova-de-trabalho (Nakamoto, 2008). A Figura 6 apresenta o fluxo e a propagação da invalidação por adulteração.

A fórmula evoluiu com o modelo e é *versionada* (`hash_version`): **hv2** cobre os campos base do evento; **hv3** acrescenta o GPS quantizado (ADR-0013) e, na restituição, a identidade documental de quem recebe a prova; **hv4** acrescenta os campos estruturados dos *actos certificados* (`authority_nome, authority_cargo, act_declared_at` e, no despacho, `act_deadline_days`). O versionamento é essencial: permite verificar *ledgers* históricos com a fórmula vigente à data de cada evento, sem reescrever o passado. A função `compute_record_hash` é *pura* (recebe o *hash* anterior como parâmetro), o que garante verificabilidade externa por qualquer perito com acesso aos campos públicos.

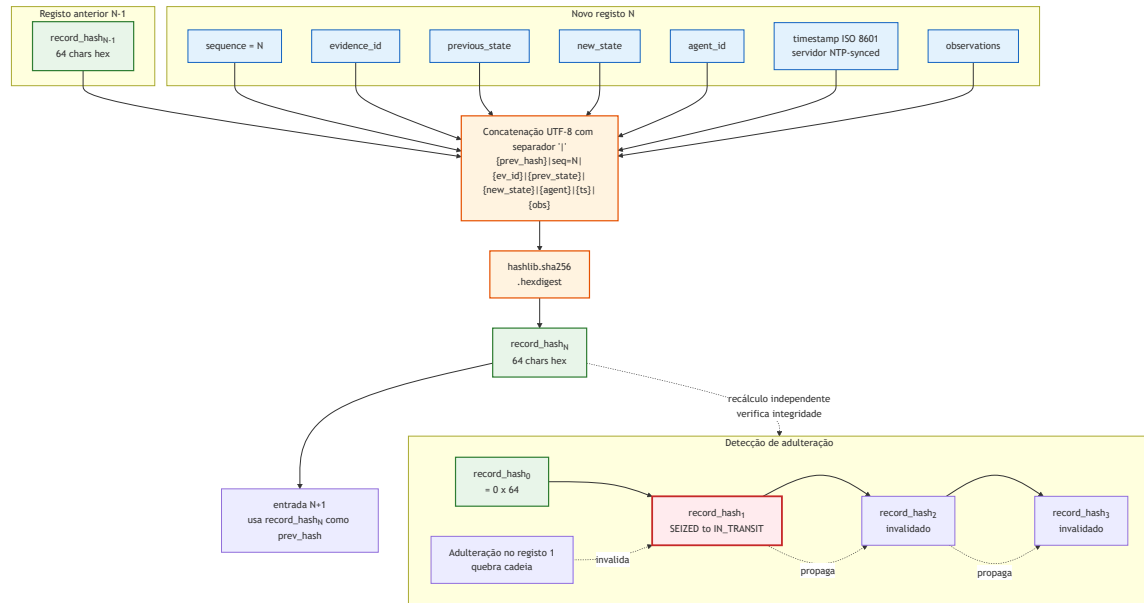


Figura 6: Fluxograma do cálculo do *hash* encadeado e da detecção de adulteração.

Actos certificados. A validação da apreensão e o despacho de perícia são *actos jurídicos*, não deslocações: o evento identifica *quem* os proferiu em campos estruturados do *ledger* (não em texto livre), os quais entram na fórmula de *hash* (hv4). A guarda vive no `clean()` do modelo (`_clean_authority`): obrigatórios nos actos certificados, recusados como identidade órfã nos restantes. Assim, “quem validou” e “quem despachou” ficam *selados* criptograficamente.

2.4.4 Sequência canónica, concorrência e atomicidade

A escrita de um evento lê o último registo do *ledger* e insere o seguinte. Sem cuidado, dois escritores concorrentes poderiam produzir *sequence* duplicada ou encadear ao mesmo predecessor. A solução combina três mecanismos PostgreSQL: `transaction.atomic()` envolve a operação; `select_for_update()` adquire *row lock* pessimista sobre o último registo e sobre a *Evidence*-pai (fechando o caso degenerado do primeiro evento, em que ainda não há linha para bloquear — correcção *B-C4* da auditoria interna); e a `UniqueConstraint(evidence, sequence)` é o invariante forense que rejeita duplicados mesmo perante *bug* aplicacional. A escolha de *sequence* (não do *timestamp*) como ordinal é deliberada: *timestamps* podem derivar entre máquinas sob dessincronização NTP.

2.4.5 Imutabilidade em três camadas

A integridade de um registo gravado é preservada por defesa em profundidade de três camadas (Figura 7): (1) **ORM Django** — a classe base `AppendOnlyModel` faz *override* de `save/delete` de instância, lançando `ValidationError` na actualização (pk não-nulo) ou eliminação ao nível do código aplicacional; (2) **DRF** — os *viewsets* declaram `http_method_names` sem `PUT/PATCH/DELETE`, devolvendo 405; (3) **triggers PostgreSQL** — funções PL/pgSQL `BEFORE UPDATE` (e, salvo no `AuditLog`, `BEFORE DELETE`) rejeitam a operação mesmo perante SQL emitido fora da aplicação. As camadas não são equivalentes: a 1.^a cobre

escritas por instância no código e a 2.^a filtra verbos HTTP, mas as operações em massa (`QuerySet.update()/delete()`, que não invocam `save()/delete()`) e o SQL directo só são travadas pela 3.^a camada — o *trigger* no SGBD é, por isso, a única garantia *transversal*. A imutabilidade quanto a *alterações* cobre `Evidence`, `ChainOfCustody`, `AuditLog` e `Occurrence`; a *eliminação* é vedada em todas excepto no `AuditLog`, cuja conservação é limitada por política de retenção (RGPD art. 5.º/1-e). Esta assimetria comporta um *trade-off* assumido: ao contrário do *ledger* encadeado, o `AuditLog` não é encadeado e é purgável, pelo que um *insider* com privilégios de expurgo (ou acesso DBA) pode eliminar entradas; o expurgo legítimo é, ele próprio, auditado como evento `AUDIT_PURGE` e qualquer lacuna fica detectável pela *sequence* global monótona.

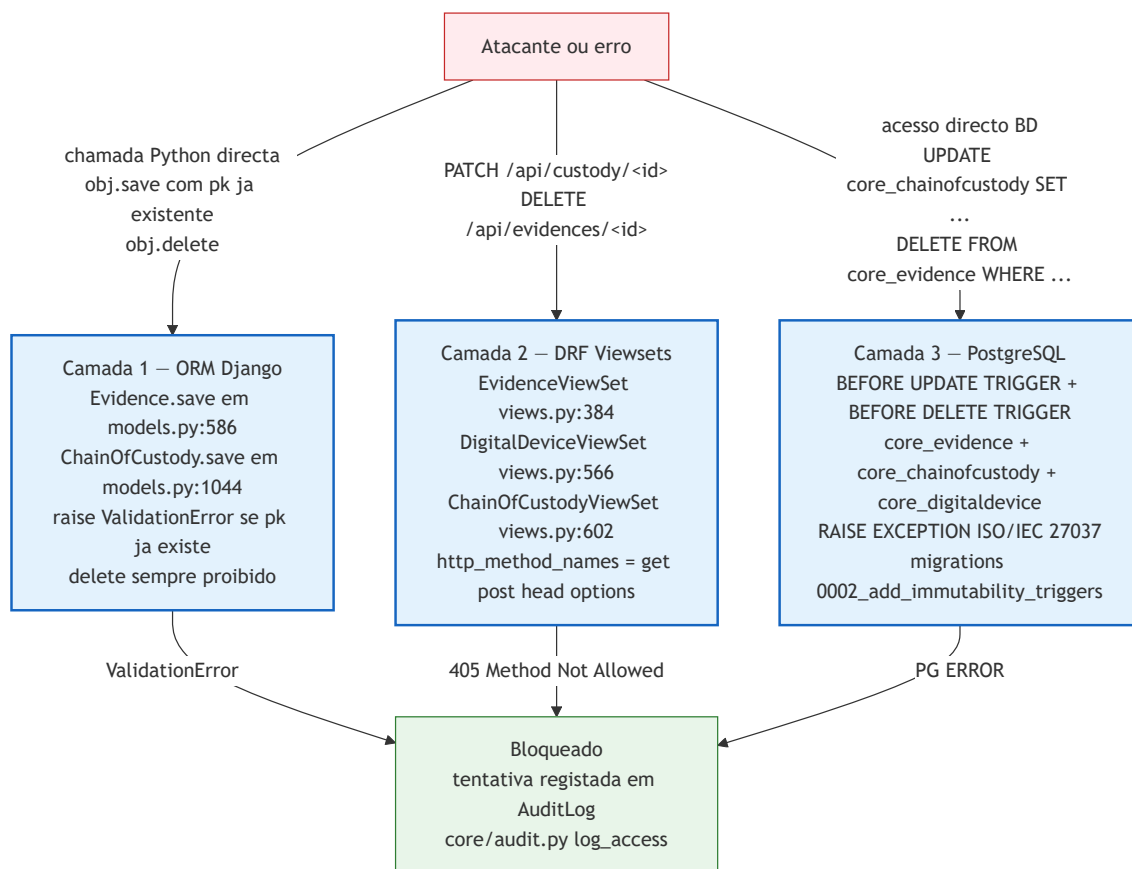


Figura 7: Defesa em profundidade contra adulteração: ORM, DRF e *triggers* PostgreSQL.

2.5 Segurança transversal

2.5.1 Autenticação JWT em *cookies* `HttpOnly`

A autenticação assenta em *tokens* JWT (Sage, 2024) transportados em *cookies* `HttpOnly` + `Secure` + `SameSite=Strict` (ADR-0009, `core/auth.py`). O transporte por *cookie* (em vez de `Authorization: Bearer` em `localStorage`) mitiga a *exfiltração* do *token* por XSS: um *cookie* `HttpOnly` é opaco ao JavaScript. A mitigação da própria injeção XSS é tratada pelo CSP nível 3 com *nonce* (§2.5.3). O *refresh* é rotativo com *blacklist*, e os *endpoints* de autenticação têm limitação de débito (*throttle*) dedicada de 5/min contra força bruta.

2.5.2 Autorização: papéis, credencial e *need-to-know*

O modelo de autorização (ADR-0017) é mais rico que o RBAC de duas funções do intercalar. As classes de permissão em `core/permissions.py` (`IsAgent`, `IsExpert`, `IsAgentOrExpert`, `CanAccessCustodyApi`, `IsOwnerOrReadOnly`) combinam-se com o controlo de acesso *item-level* em `core/access.py`: a leitura é *need-to-know* (o utilizador vê os itens em cujo *ledger* ele ou a sua instituição participam), salvo credencial NACIONAL ou função com leitura total por dever (perito). As funções CHEFE_SERVICO e AUDITOR **nunca escrevem** — o *gating* de escrita é aplicado no *render* (a UI não mostra acções) e na API (403). A protecção contra IDOR é validada por testes dedicados (§4.5).

2.5.3 Cabeçalhos HTTP de segurança

A defesa em camada HTTP combina *settings* Django e o *middleware* `ContentSecurityPolicyMiddleware`: HSTS (Hodges et al., 2012) (`max-age` 1 ano, `includeSubDomains`, `preload`), CSP nível 3 gerada por pedido com *nonce* (`secrets.token_urlsafe`), sem `unsafe-inline` nem `unsafe-eval` em `script-src`, `object-src 'none'`, `frame-ancestors 'none'` e `upgrade-insecure-requests`; `Referrer-Policy strict-origin-when-cross-origin`; `nosniff`; e políticas *cross-origin*. Todos os recursos estáticos (Leaflet, IBM Plex, Swagger UI) são *self-hosted*, eliminando a superfície de CDN externo e a necessidade de SRI.

Resolução da fragilidade CSP/Leaflet do intercalar. O intercalar receava que o Leaflet, ao posicionar os *tiles*, exigisse `style="transform:..." inline` incompatível com um `style-src` estrito (*nonce-only*). A análise final mostrou que tal não sucede: o Leaflet aplica as transformações pela propriedade do CSSOM (`element.style.transform`), que *não* é governada pela directiva `style-src`, e importa a folha de estilos por `<link>` em vez de injectar blocos `<style>`. Assim, o `style-src` mantém-se estrito — com *nonce* e sem `unsafe-inline` — e o mapa funciona: a fragilidade reconhecida no intercalar fica *resolvida* sem relaxar a política.

2.6 Conformidade ISO/IEC 27037 e RGPD Art. 32

2.6.1 Mapeamento à norma ISO/IEC 27037:2012

A Tabela 5 resume o mapeamento entre as secções relevantes da norma (ISO/IEC, 2012) e os mecanismos do ForensiQ; a matriz completa está em `docs/scope/iso27037-traceability.pdf`.

Secção	Princípio da norma	Implementação no ForensiQ
§5.2, §5.3.2	Princípios da prova digital; auditabilidade	RBAC de 6 funções + credencial (§2.5.2); JWT rotativo; AuditLog com <code>correlation_id</code> e <code>sequence</code> global.

Secção	Princípio da norma	Implementação no ForensiQ
§5.4.2	Identificação de prova digital	Evidence com 18 tipos digital-first, código hierárquico, série, GPS, <i>timestamp</i> de apreensão, <i>hash</i> .
§5.4.3–5.4.4	Recolha e aquisição	integrity_hash cobre metadados <i>e bytes</i> da foto; acquisition_hash para cópias de dados; GPS via <i>Geolocation API</i> .
§5.4.5, §6.9	Preservação de integridade	<i>Append-only</i> em 3 camadas (§2.4.5); <i>hash</i> encadeado versionado (hv4).
§6.1	Cadeia de custódia	<i>Ledger</i> de eventos com estado derivado (§2.3); actos certificados selados no <i>hash</i> .
§6.6, §7.1	Documentação; dispositivos e suportes	PDF guia de transporte com QR (ADR-0012); taxonomia + type_specific_data .

Tabela 5: Mapeamento sintético da ISO/IEC 27037:2012 aos mecanismos do ForensiQ.

2.6.2 Conformidade com o RGPD Art. 32 e evidência externa

O Artigo 32.^a (Parlamento Europeu e Conselho da União Europeia, 2016) exige medidas técnicas e organizacionais adequadas ao risco. O ForensiQ posiciona os controlos correctos em confidencialidade, integridade e auditoria (alíneas a, b), mas mantém lacunas honestamente reconhecidas: a alínea c) (restabelecimento de acesso) é endereçada parcialmente pelo plano de *disaster recovery* (`docs/operations/disaster-recovery.md`, PITR Neon + volume Fly), faltando exercício formal de RTO/RPO; e a alínea d) (avaliação regular) carece de SAST/DAST/SCA em *pipeline* e de *pentest* externo. Estas lacunas implicam que o sistema não está em condições de operar com dados reais sem as endereçar — posição defensável em contexto académico e parte da contribuição do projecto.

Três serviços externos independentes verificaram automaticamente a postura de transporte (TLS) e de cabeçalhos HTTP da produção (relatórios em `docs/compliance/external-tests/`): HSTS *Preload*, Mozilla HTTP Observatory (A+) e Qualys SSL Labs (A+) — verificações de uma dimensão específica, que não substituem o *DAST* nem o *pentest* externo referidos acima. A inclusão do domínio na lista *HSTS preload* garante HTTPS estrito mesmo no primeiro acesso, relevante para um sistema que circula prova judicial.

2.7 Interface do utilizador

A *interface* é *mobile-first* e respeita as WCAG 2.1 nível AA (World Wide Web Consortium, 2018): utilização com uma só mão, alvos tácteis ≥ 48 px, contraste $\geq 4,5:1$, *focus rings* consistentes e *live regions*. No desktop, um **modo tabela densa** servido por um gerador único de grelha (`core.grid`) oferece filtros, *multi-select* e *drill-down* por prazos (`?attn=`). A tipografia combina a *IBM Plex Sans* na interface com a *IBM Plex Mono* nos elementos

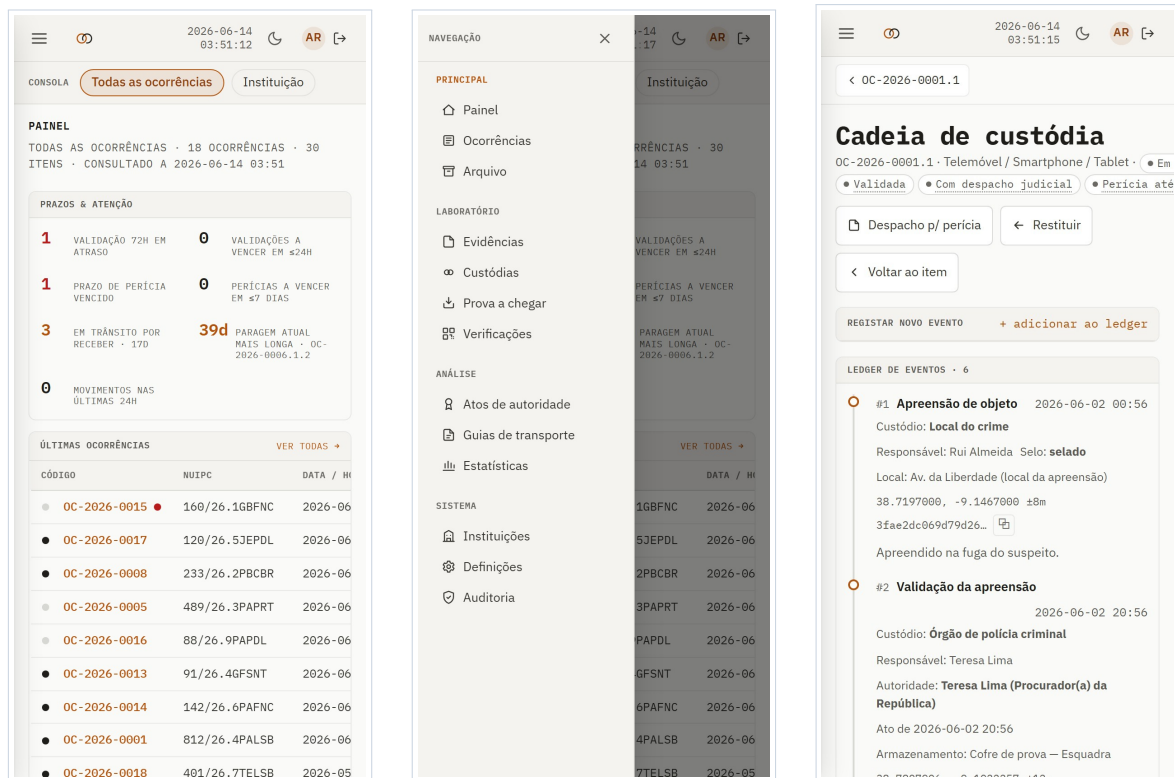


Figura 8: Interface *mobile-first* num ecrã estreito: painel reordenado, gaveta de navegação e cadeia de custódia adaptada (excerto do topo do ecrã; dados fictícios).

que exigem leitura inequívoca — *hashes* SHA-256, identificadores, *timestamps* e coordenadas GPS —, ambas *self-hosted* em *woff2*, sem dependência de CDN externo. O tema claro/escuro é alternável e persistente, com modo automático opcional por hora do dia (claro entre as 07h e as 19h), e *tokens* de cor semânticos traduzem os estados forenses derivados (*e.g.* `--state-apreendida`). O mapa de georreferenciação usa *Leaflet* sobre *OpenStreetMap* servido localmente, com captura de GPS no registo e *markers* por item no *hub* do caso. As acções de custódia são oferecidas em modais contextuais que apenas expõem as transições válidas (§2.3.3), garantindo que a *interface* nunca contraria o modelo de domínio.

Evidência visual. As figuras seguintes documentam a *interface* tal como entregue, na instância de demonstração (dados fictícios). A Figura 8 mostra a vista *mobile-first* num ecrã estreito — painel reordenado, gaveta de navegação e cadeia de custódia adaptada —, que sustenta o requisito de utilização com uma só mão (RNF02). A Figura 9 mostra a *timeline* do *ledger* de um item, com o custódio, o responsável, o selo, o GPS e o *hash* encadeado de cada evento. A Figura 10 mostra o modal de um acto certificado (despacho de perícia), em que a identidade da autoridade entra na fórmula de *hash* (hv4, §2.4.3).

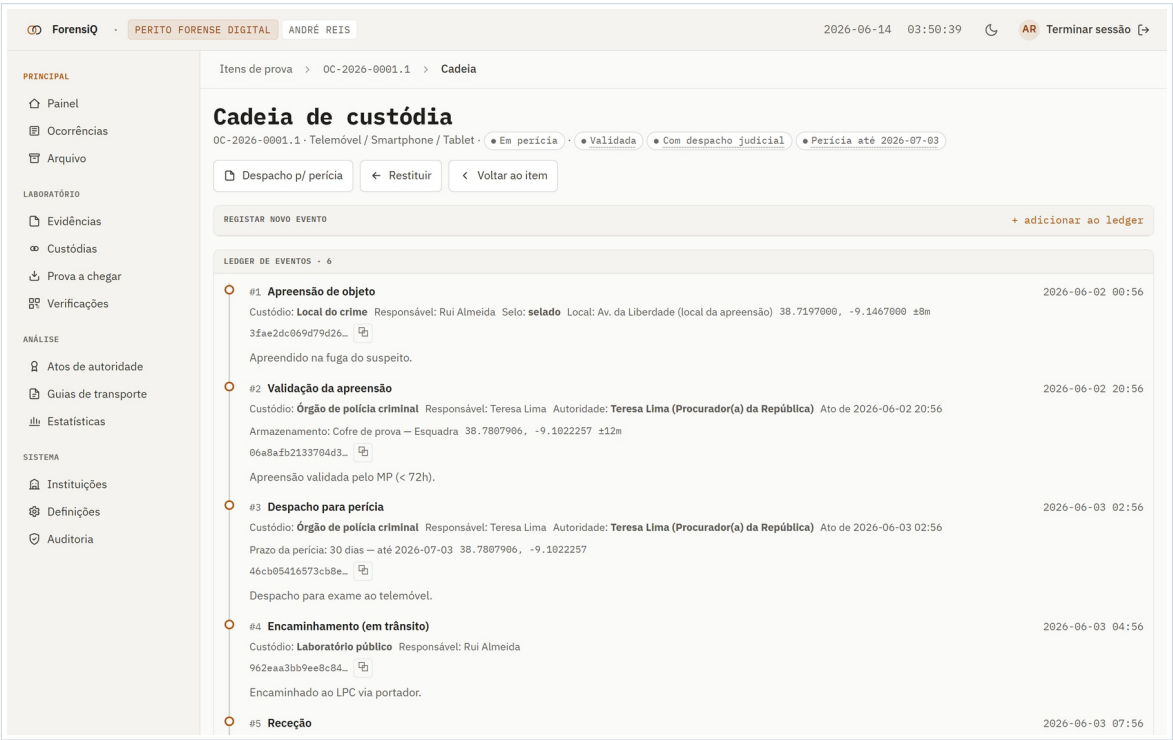


Figura 9: *Timeline* da cadeia de custódia de um item (*ledger*): cada evento traz o custódio, o responsável, o selo, o GPS e o *hash* encadeado.

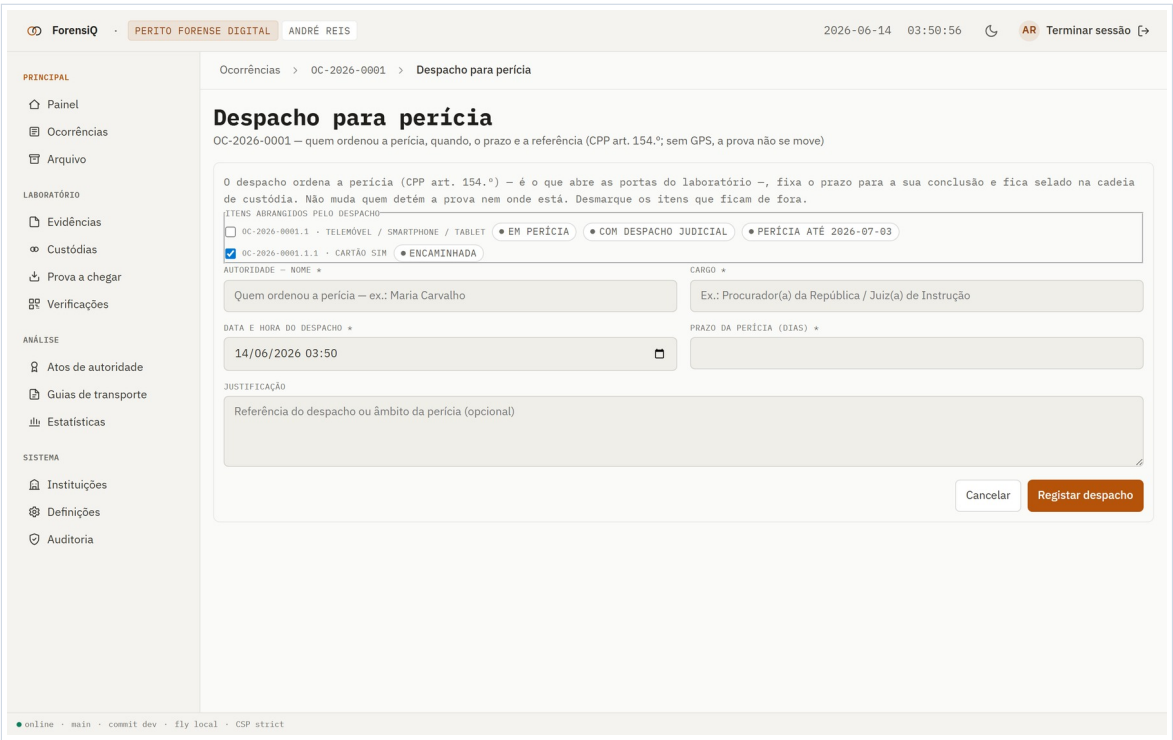


Figura 10: Modal de acto certificado (despacho de perícia): itens abrangidos, identidade da autoridade, data, prazo da perícia e justificação. A identidade é selada no *hash* (hv4).

3 Implementação

Este capítulo documenta o estado *final* de implementação, à data da entrega (24 jun 2026). Apresenta a decomposição de tarefas (§3.1), o estado por componente (§3.2), o cumprimento dos critérios de aceitação (§3.4), os desvios ao plano (§3.5) e a demonstração em produção (§3.6). A avaliação por testes é o objecto do Capítulo 4.

3.1 Decomposição do trabalho

O trabalho decompôs-se em duas grandes fases. A Fase A (Sem. 1–8) entregou o MVP descrito no intercalar. A Fase B (Sem. 9–16) consolidou, endureceu e *refactorizou* o sistema para a versão final. A Tabela 6 resume as tarefas com precedências; todas estão concluídas, à excepção da redacção final (em curso à data).

T	Tarefa	Precedências	Estado
T1	Repositório, proposta, MoSCoW	—	Concluída
T2	ADRs 0001–0010 (base)	T1	Concluída
T3	Modelo de dados <i>core</i> + integridade SHA-256	T2	Concluída
T4	Autenticação JWT (cookies HttpOnly) + CSRF	T3	Concluída
T5	API REST e <i>viewsets</i>	T3, T4	Concluída
T6	<i>Frontend mobile-first</i>	T5	Concluída
T7	Imutabilidade em 3 camadas (ORM, DRF, <i>triggers</i>)	T3, T5	Concluída
T8	Auditorias internas + endurecimento (<i>hardening</i>) de segurança	T7	Concluída
T9	<i>Deployment</i> Fly.io + Neon; HSTS <i>preload</i>	T6	Concluída
T10	Exportação PDF + QR + verificação pública (ADR-0012)	T5, T6	Concluída
T11	<i>Ledger</i> de custódia + estado derivado (ADR-0015)	T3, T8	Concluída
T12	IDs hierárquicos + custódia v2 (ADR-0016)	T11	Concluída
T13	Papéis, credencial, instituições, <i>need-to-know</i> (ADR-0017)	T11	Concluída
T14	Taxonomia de crimes + prioridade (ADR-0014)	T3	Concluída
T15	Actos certificados (validação, despacho) — <i>hash</i> v4	T11, T13	Concluída
T16	Política numa fonte única (<i>core/policy</i> , ADR-0019)	T11	Concluída

T	Tarefa	Precedências	Estado
T17	<i>Rebuild</i> do frontend (HTMX) + gerador de grelha	T6, T11	Concluída
T18	Subequipamentos + consola de auditoria + analytics SLA	T12, T16	Concluída
T19	Relatório final (Cap. 1–5)	T1–T18	Em curso

Tabela 6: Decomposição de tarefas com precedências (Fase A: T1–T10; Fase B: T11–T19).

3.2 Estado final por componente

A Tabela 7 resume o estado de cada componente na versão final. Verde indica conclusão validada por testes; amarelo, funcionalidade entregue com limitação reconhecida; vermelho, funcionalidade fora do âmbito do MVP.

Componente	Estado	Observação
<i>Backend</i> Django 6 + DRF	verde	Modelos, <i>viewsets</i> , serializadores, permissões; ≈ 955 testes (Cap. 4).
<i>Ledger</i> de custódia (ADR-0015)	verde	Eventos <i>append-only</i> ; estado legal derivado; <i>hash</i> encadeado hv4.
Política de domínio (core/policy)	verde	Vocabulário, guardas e derivação puros, sem ORM (ADR-0019); fonte única.
Actos certificados (validação, despacho)	verde	Autoridade estruturada selada no <i>hash</i> ; prazos CPP 178/154.
RBAC 6 funções + credencial + instituições	verde	Acesso <i>need-to-know</i> ; só-leitura aplicado no <i>render</i> e na API (ADR-0017).
Imutabilidade em 3 camadas	verde	ORM + DRF + <i>triggers</i> PG (Evidence, ChainOfCustody, AuditLog, Occurrence).
Autenticação JWT em <i>cookies</i>	verde	HttpOnly + Secure + SameSite; CSRF; <i>refresh</i> rotativo; <i>throttle</i> 5/min.
<i>Frontend</i> server-rendered (HTMX)	verde	Gerador único de grelha; modo tabela densa; mapa Leaflet; WCAG 2.1 AA.
Exportação PDF + QR (ADR-0012)	verde	Guia de transporte; <i>endpoint</i> público de verificação por <i>hash</i> .
<i>Deployment</i>	verde	Fly.io fra + Neon; HTTPS A+ (Qualys); HSTS <i>preload</i> ; Observatory A+.
Cobertura de testes	verde	90,90% medida em PostgreSQL; <i>gate</i> CI a 80% (§4.7).

Componente	Estado	Observação
<i>Backups</i> de media/	amarelo	PITR Neon (BD) + volume Fly; sem exercício formal de RTO/RPO (RGPD 32 c).
SAST/SCA em CI	verde	Bandit (SAST) + pip-audit/Trivy (SCA) + Gitleaks por <i>pull request</i> , <i>push</i> e semanalmente (<i>security.yml</i>); DAST em CI e <i>pentest</i> externo ficam trabalho futuro (RGPD 32 d).

Tabela 7: Estado por componente na versão final.

3.3 Mecanismos centrais de integridade e custódia

As garantias forenses do ForensiQ não residem numa funcionalidade isolada, mas num pequeno conjunto de mecanismos de domínio, propositadamente concentrados e testáveis. Esta secção apresenta excertos do código de produção — verificados linha a linha contra o repositório — que materializam os quatro pilares do modelo: o *hash* encadeado, a escrita serializada *append-only*, a imutabilidade em profundidade e a derivação do estado legal.

Integridade por *hash* encadeado. Cada evento da cadeia é selado por um *hash* SHA-256 que incorpora o *hash* do evento anterior (`ChainOfCustody.compute_record_hash`, `core/models.py`). A função é *pura* e determinística — recebe o `previous_hash` como argumento em vez de o ler da base de dados —, de modo a que qualquer perito independente possa recalculer a cadeia a partir dos campos públicos relidos e detectar qualquer adulteração (ISO/IEC 27037, §5.4.5; ADR-0013). As versões hv2 a hv4 seguem um *contrato aditivo*: prefixam a versão e acrescentam segmentos no fim (portador, receptor, autoridade do acto certificado), sem nunca reordenar os segmentos originais, pelo que *ledgers* antigos permanecem verificáveis com a fórmula da sua época.

```

1 def compute_record_hash(self, previous_hash: str | None = None) -> str:
2     """SHA-256 encadeado do evento (fórmula única, ADR-0013). Puro e
3     determinístico: recebe previous_hash como argumento, para um perito
4     independente poder recalculer a cadeia a partir dos campos relidos da
5     base de dados (excerto; docstring integral no código-fonte)."""
6     if previous_hash is None:
7         previous_hash = self._lookup_previous_hash()
8
9     data = (
10         f'{previous_hash}|'
11         f'seq={self.sequence}|'
12         f'{self.evidence_id}|'
13         f'{self.event_type}|'
14         f'{self.custodian_type}|'
15         f'{self.agent_id}|'
16         f'{self.timestamp.isoformat()}|'
17         f'_{hash_str(self.gps_lat)}|'
18         f'_{hash_str(self.gps_lng)}|'
19         f'_{hash_str(self.gps_accuracy_m)}|'

```



```

20         f'_{_hash_escape(self.location_name)}|',
21         f'_{_hash_escape(self.storage_location)}|',
22         f'{self.observations}',
23         f'|sealed={int(self.sealed)}',
24         f'|sealcond={self.seal_condition_on_receipt}',
25         f'|newseal={_hash_escape(self.new_seal_number)}',
26         f'|relinq={self.relinquished_by_id or ""}',
27     )
28
29     # Contrato aditivo (ADR-0016): hv2-hv4 prefixam a versão e acrescentam
30     # campos no FIM, sem reordenar os segmentos hv1.
31     version = self.hash_version or 'hv1'
32     if version in ('hv2', 'hv3', 'hv4'):
33         data = (
34             f'_{version}|{data}',
35             f'|bmat={_hash_escape(self.bearer_matricula)}',
36             f'|bnome={_hash_escape(self.bearer_nome)}',
37             f'|bapel={_hash_escape(self.bearer_apelido)}',
38             f'|bposto={_hash_escape(self.bearer_posto)}',
39         )
40     if version in ('hv3', 'hv4'):
41         data += (
42             f'|rnome={_hash_escape(self.receiver_nome)}',
43             f'|rdoctipo={self.receiver_doc_tipo}',
44             f'|rdocnum={_hash_escape(self.receiver_doc_numero)}',
45         )
46     if version == 'hv4':
47         adata = self.act_declared_at.isoformat() if self.act_declared_at else
48         ''
49         data += (
50             f'|anome={_hash_escape(self.authority_nome)}',
51             f'|acargo={_hash_escape(self.authority_cargo)}',
52             f'|adata={adata}',
53             f'|aprazo={_hash_str(self.act_deadline_days)}',
54         )
55     return hashlib.sha256(data.encode('utf-8')).hexdigest()

```

Listagem 1: Cálculo do *hash* SHA-256 encadeado
(ChainOfCustody.compute_record_hash, core/models.py; excerto).

Escape de separadores e canonicalização. Os campos de texto livre que entram na fórmula — `location_name`, `storage_location`, números de selo e os *snapshots* de portador, receptor e autoridade — passam por `_hash_escape` (`\`, `|` e `,` são escapados), impedindo colisão com os separadores. Excepção assumida: `observations` entra sem *escape*, pelo que a serialização não é estritamente injectiva em relação aos campos terminais do segmento (selo e `relinquished_by`); um `observations` construído poderia, em teoria, reproduzir a concatenação de outra combinação desses campos sem quebrar o SHA-256. A ameaça é residual e aceite: o registo é *append-only* (os *triggers* do SGBD bloqueiam UPDATE/DELETE), o tuplo atacável não inclui localização nem identidades (essas estão escapadas), e a normalização de `observations` está planeada para uma futura versão de *hash* (hv5), que lhe aplicará *escape*

como aos restantes campos de texto livre.

Escrita serializada *append-only*. O número de sequência de cada acto e o seu encadeamento de *hash* são calculados dentro de um único `transaction.atomic()` com `select_for_update()` sobre a evidência-mãe e sobre o último registo, eliminando condições de corrida entre dois peritos a gravar em simultâneo (correções B-C2 a B-C4 da auditoria de concorrência). A `UniqueConstraint(evidence, sequence)` (`core/models.py`) é a rede de segurança final ao nível do SGBD; o *timestamp* é sempre o do servidor (NTP), nunca o do cliente.

```

1 def save(self, *args, **kwargs) -> None:
2     """Append-only: só permite criação. O sequence é determinado a partir
3     do último registo (nunca do cliente) e o timestamp é do servidor. Toda
4     a lógica vive num transaction.atomic() com select_for_update() (fixes
5     B-C2/B-C3/B-C4 da auditoria de concorrência). Excerto."""
6     self._assert_insert_only()
7
8     for _ in range(CODE_MAX_ATTEMPTS):
9         try:
10             with transaction.atomic():
11                 # Lock pessimista na Evidence pai: cobre o ledger ainda
12                 # vazio, em que .first() devolveria None (sem row a bloquear)
13
14                 Evidence.objects.select_for_update().filter(pk=self.
15                     evidence_id).first()
16
17                 last_record = (
18                     ChainOfCustody.objects.select_for_update()
19                     .filter(evidence=self.evidence)
20                     .order_by('-sequence')
21                     .first()
22                 )
23                 self.sequence = (last_record.sequence + 1) if last_record
24                     else 1
25                 self.timestamp = timezone.now() # sempre do servidor (NTP)
26                 if not self.code:
27                     self.code = f'{self.evidence.code}-M{self.sequence:02d}'
28
29                 self.hash_version = 'hv4'
30                 if self.bearer_id is not None:
31                     self.bearer_matricula = self.bearer.matricula
32                     self.bearer_nome = self.bearer.nome
33                     self.bearer_apelido = self.bearer.apelido
34                     self.bearer_posto = self.bearer.posto
35
36                 self.full_clean()
37                 previous_hash = last_record.record_hash if last_record else
38                     GENESIS_HASH
39                 self.record_hash = self.compute_record_hash(previous_hash=
40                     previous_hash)
41                 super().save(*args, **kwargs)

```

```

37         # [...] caixa "prova a chegar" criada no mesmo atomic (
           omitida)
38     return
39 except IntegrityError as exc:
40     if not _is_unique_collision(exc, 'code'):
41         raise
42     self.code = ''
43     self.pk = None
44 raise RuntimeError(
45     'Não foi possível gerar um código de movimento único após várias
      tentativas.'
46 )

```

Listagem 2: Escrita serializada e *append-only* de um acto de custódia (ChainOfCustody.save, core/models.py; excerto).

Imutabilidade em profundidade. A imutabilidade é imposta em três camadas. Na camada da aplicação, a base abstrata `AppendOnlyModel` faz *override* de *save/delete* de instância: rejeita o `UPDATE` (*save* com chave primária existente) e proíbe o `delete` (Listagem 3). A camada da API (DRF) restringe os métodos HTTP a `GET/POST`. Estas duas camadas não interceptam, porém, as operações em massa (`QuerySet.update()/delete()`), que em Django não invocam `save()/delete()` nem o SQL directo. Por isso, como garantia *transversal* e última linha de defesa, *triggers* PL/pgSQL ao nível do PostgreSQL abortam qualquer `UPDATE` ou `DELETE` mesmo que se contorne inteiramente o Django — decisivo contra operações em massa e contra um adversário com acesso SQL directo (Listagem 4).

```

1 class AppendOnlyModel(models.Model):
2     """Base abstrata dos registos IMUTÁVEIS: save só admite inserção e
3     delete é sempre recusado (ISO/IEC 27037; os triggers da base de dados
4     são a 2.a linha de defesa)."""
5
6     immutable_save_msg = 'Registos são imutáveis. Não é permitido atualizar
      registos existentes.'
7     immutable_delete_msg = 'Registos são imutáveis. Não é permitido eliminar
      registos.'
8
9     class Meta:
10         abstract = True
11
12     def _assert_insert_only(self) -> None:
13         if self.pk is not None:
14             raise ValidationError(self.immutable_save_msg)
15
16     def delete(self, *args, **kwargs) -> NoReturn:
17         raise ValidationError(self.immutable_delete_msg)

```

Listagem 3: Imutabilidade, 1.^a camada (ORM): `AppendOnlyModel` (core/models.py).

```

1 CUSTODY_FORWARD_SQL = """
2     CREATE OR REPLACE FUNCTION prevent_custody_modification()
3     RETURNS TRIGGER AS $$

```

```

4 BEGIN
5     RAISE EXCEPTION
6         'Registos de cadeia de custódia são imutáveis (ISO/IEC 27037). '
7         'Operação bloqueada: %%', TG_OP;
8 END;
9 $$ LANGUAGE plpgsql;
10
11 CREATE TRIGGER trg_custody_no_update
12     BEFORE UPDATE ON core_chainofcustody
13     FOR EACH ROW
14     EXECUTE FUNCTION prevent_custody_modification();
15
16 CREATE TRIGGER trg_custody_no_delete
17     BEFORE DELETE ON core_chainofcustody
18     FOR EACH ROW
19     EXECUTE FUNCTION prevent_custody_modification();
20 """

```

Listagem 4: Imutabilidade, 2.^a camada (SGBD): *trigger* PL/pgSQL que aborta UPDATE/DELETE (migrations/0002_add_immutability_triggers.py; SQL inverso omitido).

Estado legal derivado. O estado legal de um item nunca é gravado como coluna mutável: é sempre *re-derivado* da leitura do *ledger* imutável pela função pura `derive_legal_state` (`core/policy/event_states.py`), fonte única do estado em todo o *backend* e *frontend* (ADR-0015, ADR-0019). Por construção, o estado não pode ser falsificado nem dessincronizar-se dos factos. A guarda de transição que decide os actos legalmente admissíveis como próximo evento — `next_events` (`core/policy/custody_transitions.py`) — partilha os mesmos predicados puros que o `ChainOfCustody.clean` (`core/models.py`) aplica na escrita, pelo que o ecrã nunca propõe um acto que o modelo recuse.

```

1 def derive_legal_state(eventos_ordenados: list[LedgerRecord]) -> str:
2     """Estado legal DERIVADO da sequência de eventos (ADR-0015). Função
3     pura e fonte única do estado em todo o backend e frontend. Devolve uma
4     de: a_guarda_opc | em_pericia | pericia_concluida | em_transito |
5     encaminhada | restituída | perdida_favor_estado | destruída. Excerto."""
6     if not eventos_ordenados:
7         return 'a_guarda_opc'
8
9     tipos = [r.event_type for r in eventos_ordenados]
10    ultimo = eventos_ordenados[-1]
11    et = ultimo.event_type
12
13    # Terminais (pelo último evento) fecham o ledger.
14    if et == EventType.DESTRUICAO:
15        return 'destruída'
16    if et == EventType.RESTITUICAO:
17        return 'restituída'
18
19    # Perda a favor do Estado: estatuto legal forte, domina enquanto presente

```

```

20     if EventType.PERDA_FAVOR_ESTADO in tipos:
21         return 'perdida_favor_estado'
22
23     # Caso geral: o estado segue o ULTIMO acto relevante (nao-linearidade).
24     if et == EventType.INICIO_PERICIA:
25         return 'em_pericia'
26     if et == EventType.CONCLUSAO_PERICIA:
27         return 'pericia_concluida'
28     if et == EventType.ENCAMINHAMENTO_CUSTODIA:
29         return 'em_transito'
30     if et in (
31         EventType.RECEPCAO_CUSTODIA,
32         EventType.TRANSFERENCIA_CUSTODIA,
33         EventType.ASSUNCAO_CUSTODIA,
34     ):
35         return 'a_guarda_opc' if ultimo.custodian_type == CustodianType.OPC
36         else 'encaminhada'
37
38     if et in GENESIS_EVENTS:
39         return 'a_guarda_opc' if ultimo.custodian_type == CustodianType.OPC
40         else 'encaminhada'
41
42     # DESPACHO_PERICIA / VALIDACAO_APREENSAO: a prova nao se moveu.
43     return 'a_guarda_opc'

```

Listagem 5: Derivação do estado legal a partir do *ledger* (*derive_legal_state*, *core/policy/event_states.py*; excerto).

A coerência destes quatro mecanismos — e não a sua complexidade individual — é a contribuição técnica central do projecto (§5.1).

3.4 Cumprimento dos critérios de aceitação

A Tabela 8 confronta os requisitos de *docs/scope/requirements.md* com a sua verificação na versão final. Todos os *Must have* e *Should have* estão cumpridos. Relativamente ao intercalar, três *Could have* passaram a cumpridos de forma documentada: RF10 (funções adicionais — materializadas como *CHEFE_SERVICO* e *CASE_AUTHORITY/MP* no ADR-0017), RF11 (verificação de IMEI via *API* externa *imeidb.xyz*, ADR-0008) e RF13 (despachos judiciais — materializados como acto certificado *DESPACHO_PERICIA*, antes “não realizado”).

ID	Requisito	Prior.	Estado (final)
RF01	Autenticação JWT com funções	Must	Cumprido
RF02	Ocorrências com georreferenciação	Must	Cumprido
RF03	Registo de prova com foto, GPS, <i>hash</i>	Must	Cumprido
RF04	Ficha digital da evidência	Must	Cumprido (taxonomia + type_specific_data)
RF05	Cadeia de custódia <i>append-only</i>	Must	Cumprido (<i>ledger</i> , ADR-0015)

ID	Requisito	Prior.	Estado (final)
RF06	Exportação PDF	Must	Cumprido (+ QR, ADR-0012)
RF07	API REST documentada	Must	Cumprido
RF08	<i>Dashboard</i> por estado	Should	Cumprido (métricas de fluxo)
RF09	Pesquisa e filtragem	Should	Cumprido (modo tabela densa)
RF10	Funções adicionais (coordenador, magistrado)	Could	Cumprido (ADR-0017)
RF11	Verificação de IMEI via <i>API</i> externa	Could	Cumprido (ADR-0008)
RF12	<i>Dashboard</i> analítico	Could	Cumprido (SLA/ <i>dwell</i> ; por agente parcial)
RF13	Despachos judiciais	Could	Cumprido (acto certificado)
RF14–17	Integração PSP, dados reais, módulos QBF, <i>app</i> nativa	Won't	Fora do âmbito
RNF01	HTTPS obrigatório	Must	Cumprido (HSTS <i>preload</i> + Qualys A+)
RNF02	<i>Mobile-first</i> utilizável com uma só mão	Must	Cumprido (WCAG 2.1 AA)
RNF03	Integridade SHA-256 e <i>append-only</i>	Must	Cumprido (3 camadas + hv4)
RNF04	Resposta inferior a 2 s	Should	Verificado em produção (Lighthouse <i>perf</i> 93–99/100, §4.6)
RNF05	Testes automatizados em módulos críticos	Should	Cumprido (≈955 testes)
RNF06	<i>Deployment</i> público	Could	forensiq.pt

Tabela 8: Cumprimento dos requisitos funcionais e não-funcionais (versão final).

3.5 Desvios ao plano e evolução de âmbito

A execução afastou-se do plano da proposta em pontos que importa documentar com honestidade, conforme o Guia.

Demo interna síncrona (Sem. 7). Não foi realizada na janela prevista (28 abr–2 mai); foi substituída por demonstração assíncrona em produção, comunicada ao orientador com o intercalar. A modalidade permitiu exercitar todos os fluxos críticos sem ambiente local.

Refactor de fundo da Fase 2/3. A decisão de maior impacto foi reconhecer, ainda no intercalar, que a máquina de estados linear era um modelo inadequado, e *corrigi-la* em vez de a manter. O *refactor* (ADR-0014 a 0019) substituiu-a por um *ledger* de eventos, introduziu identificação hierárquica, papéis/instituições e actos certificados. Esta foi uma evolução de âmbito *para além* do MVP da proposta — aceitável porque o núcleo estava sólido (Guia §6) — e está integralmente rastreada nos ADRs e no *changelog.md*. O custo

foi assumido conscientemente: parte do código e dos testes do intercalar foi reescrita sem retrocompatibilidade (princípio da Fase 2), e a demo foi regerada.

Frontend: de *vanilla* para HTMX. A SPA de JavaScript por página foi abandonada a favor de *templates server-rendered* com HTMX, eliminando o *contract drift* entre o estado calculado no *backend* e o replicado no cliente (ADR-0004 revisto).

Concentração de *commits* na recta final. O risco R07 (`risks.md`) materializou-se em parte: a Fase 2/3 concentrou actividade em Junho. A mitigação efectiva foi a cadência regular ao longo de todo o semestre, o uso de *branches/pull requests* e de mensagens *Conventional Commits* (Conventional Commits Working Group, 2024) descritivas, e revisões adversariais sistemáticas por lote — evidência de processo contínuo, não de um *dump* final. O histórico do repositório é auditável pelo júri.

Operação *offline* no terreno. Mantém-se fora do âmbito: o registo exige ligação activa no momento da submissão. A robustez *offline* (PWA leve com fila de submissões assinadas) é trabalho futuro de prioridade alta (§5.3).

3.6 Demonstração em produção

O ambiente em forensiq.pt é uma cópia plenamente funcional, alojada em Fly.io Frankfurt com PostgreSQL Neon na mesma região. O *management command* `seed_demo` popula um conjunto realista com ocorrências em cidades portuguesas, respectivos NUIPCs sintéticos e itens de prova distribuídos pela taxonomia, incluindo sub-componentes hierárquicos; as fotografias são *placeholder* sintéticas, sem qualquer dado pessoal real. O *seed* provisiona as **seis funções** do ADR-0017 (agente, perito, custódio, autoridade/MP, chefe de serviço e auditor), permitindo demonstrar o acesso *need-to-know* e os actos certificados. As credenciais do orientador são entregues por canal privado e não constam do repositório, por princípio de segurança (ISO/IEC 27037; OWASP A07:2021 (OWASP Foundation, 2021)).

ForensiQ · PERITO FORENSE DIGITAL ANDRÉ REIS

2026-06-14 03:50:30 AR Terminar sessão

PRINCIPAL

Painel

Ocorrências

Arquivo

LABORATÓRIO

Evidências

Custódias

Prova a chegar

Verificações

ANÁLISE

Atos de autoridade

Guias de transporte

Estatísticas

SISTEMA

Instituições

Definições

Auditoria

CONSOLA

Todas as ocorrências Instituição

Ocorrências 15 registros

Q Procurar código, NUJPC, crime, local, agente...

Ordenar Mais recentes

PRT.	CÓDIGO	NUJPC	TIPO DE CRIME	DATA	LOCAL	ONDE ESTÁ
Todos			Todos	Todas		
-	OC-2026-0015	160/26.168FNC	33 — Furto em residência com arr...	2026-06-10 22:36	Estrada Monumental, Funchal	PSP-FNC
P1	OC-2026-0017	120/26.53EPDL	111 — Tráfico de estupefacientes (...)	2026-06-09 21:36	Portas do Mar, Ponta Delgada	INMLCF-S
P1	OC-2026-0008	233/26.2PBCBR	159 — Falsidade informática	2026-06-08 19:36	Praça 8 de Maio, Coimbra	INMLCF-C
-	OC-2026-0005	489/26.3PAPRT	16 — Ameaça e coação	2026-06-08 01:36	Rua de Santa Catarina 215, ...	PSP-PRT
-	OC-2026-0016	88/26.9PAPDL	63 — Discriminação e incitamento ...	2026-06-07 01:36	Avenida Infante D. Henrique,...	PSP-PDL
P1	OC-2026-0013	91/26.46FSNT	74 — Incêndio/fogo posto floresta...	2026-06-05 21:36	Serra de Sintra	GNR
P1	OC-2026-0014	142/26.6PAFNC	194 — Violência doméstica contra ...	2026-06-05 00:36	Rua da Carreira, Funchal	PSP-FNC
P1	OC-2026-0001	812/26.4PALSB	40 — Roubo na via pública (except...	2026-06-01 23:36	Avenida da Liberdade 250, L...	LPC
P1	OC-2026-0018	401/26.7TELSB	157 — Acesso indevido ou ilegítim...	2026-05-31 01:36	Morada reservada (sem geor...	GAB
P1	OC-2026-0007	902/26.6JAPRT	160 — Sabotagem informática	2026-05-29 22:36	Avenida da Boavista 1200, P...	2 locais
P1	OC-2026-0012	540/26.3TAPRT	102 — Branqueamento de vantagem...	2026-05-27 00:36	Rua de Cedofeita 300, Porto	2 locais
P2	OC-2026-0002	345/26.1PFLSB	241 — Burla informática/comunic...	2026-05-25 01:36	Rua de Entrecampos 28, Lis...	FOREN
P1	OC-2026-0011	318/26.130LSB	199 — Lenocínio e pornografia de ...	2026-05-19 23:36	Avenida de Roma 90, Lisboa	2 locais

Figura 11: Lista de ocorrências em modo tabela densa, com pesquisa, filtros e prioridade derivada por política criminal (instância de demonstração, dados fictícios).

38

ForensiQ

AGENTE / PRIMEIRO INTERVENIENTE

RUI ALMEIDA

2026-06-14 03:51:09

Terminar sessão

PRINCIPAL

Painel

Ocorrências

Nova ocorrência

Arquivo

LABORATÓRIO

Evidências

Novo item

Custódias

Prova a chegar

ANÁLISE

Atos de autoridade

Guias de transporte

Estadísticas

SISTEMA

Definições

Auditoria

Itens de prova > Nova

LOCAL DA APREENSÃO

Usar a minha localização

Permissão de localização negada – autorize-a no browser. Clique no mapa ou escreva as coordenadas.

LATITUDE

38.7197

LONGITUDE

-9.1467

CONTEXTO

OCORRÊNCIA *

—selecionar—

SUB-COMPONENTE DE (OPCIONAL)

— nenhum (item raiz) —

IDENTIFICAÇÃO DO ITEM

TIPO *

—selecionar—

FOTOGRAFIA

Choose File | No file chosen

DESCRIÇÃO *

Descrição do item apreendido...

MARCA / FABRICANTE

MODELO

ESTADO DE ENERGIA NA APREENSÃO

—selecionar—

NÚMERO DE SÉRIE

Cancelar

Registrar evidência

online · main · commit dev · fly local · CSP strict

Figura 12: Registo de prova no terreno (F2): captura de GPS pela *Geolocation API*, fotografia e atributos por tipo; o *timestamp* é do servidor (NTP) e o *hash* SHA-256 é calculado na criação.

39

4 Testes

Este capítulo apresenta a estratégia de teste do ForensiQ e os resultados obtidos. A filosofia segue a *pirâmide de testes* (Fowler, 2012): uma base larga de testes de unidade e integração rápidos sobre a lógica de domínio, e um topo mais estreito de testes *end-to-end* de *browser* que validam a interacção real. O princípio orientador é o do Guia: os testes documentados aqui *cobrem os critérios de aceitação* definidos na proposta, e um sistema que funciona no caminho feliz mas falha em casos-limite previsíveis demonstra falta de rigor de engenharia.

4.1 Estratégia e camadas

- **Unidade** — modelos, validadores, serviços e a camada de política pura (*core/policy*), que é testável sem ORM por desenho (ADR-0019).
- **Integração** — vista + base de dados + serializador: *endpoints* DRF, permissões, *throttle*, filtros, geração de PDF.
- **End-to-end (E2E)** — *browser* real via Playwright sobre *live_server*: fluxos completos, CSP, HTMX, captura de GPS, *upload* de ficheiros, modais de acto e cascatas.
- **Acessibilidade e rapidez** — *axe-core* (WCAG) integrado no Playwright, validado em tema claro e escuro; *Lighthouse* para rapidez de laboratório com orçamentos.

A *suíte* unitária/integração corre com `pytest` sobre `test_settings` (**PostgreSQL**, em paridade total com produção — o projecto é PostgreSQL-only), enquanto a E2E corre em separado (`pytest e2e/ -ds=forensiq_project.e2e_settings`), para que um `pytest` simples ou o *job* de CI nunca tentem arrancar o Playwright.

4.2 Dimensão e distribuição da *suíte*

À data da entrega, a *suíte* unitária/integração em *core/* contém **955 métodos de teste** distribuídos por 42 ficheiros `tests_*.py`, mais **38 testes E2E** em 14 ficheiros.¹ A Tabela 9 resume os maiores ficheiros, por área.

Ficheiro de teste	Métodos	Área
<code>tests_coverage.py</code>	76	Conteúdo PDF, integridade, CSP/CORS
<code>tests_api.py</code>	74	API, JWT, IDOR, imutabilidade, <i>throttle</i>
<code>tests_services.py</code>	70	Serviços externos (IMEI/VIN, geocoding)
<code>tests.py</code>	68	Modelos e validação
<code>tests_frontend.py</code>	59	Vistas, <i>templates</i> , contexto
<code>tests_despacho.py</code>	45	Despacho de perícia (acto certificado)

¹Contagem estática reproduzível (`grep -rhcE "^s*def test_" core/tests*.py`), que soma 955. Executados contra **PostgreSQL** (o projecto é PostgreSQL-only), **os 955 passam e nenhum é ignorado** — incluindo os testes dos *triggers* de imutabilidade, que correm de facto contra a base de dados real. A *suíte* cresceu de 213 testes (intercalar, 6 mai) para este valor, sobretudo com os lotes de actos certificados, subequipamentos e serviços de Junho.

Ficheiro de teste	Métodos	Área
tests_access.py	41	<i>Need-to-know</i> , instituições, credencial
tests_subequipamentos.py	35	Hierarquia, génese por derivação
tests_new_features.py	34	Funcionalidades da Fase B
tests_policy_custody_transitions.py	30	Guardas de transição (política)
tests_validar.py	27	Validação da apreensão (CPP 178)
tests_guia.py / tests_grid.py	10 / 27	PDF da guia de transporte; gerador de grelha
tests_atos_consulta.py	24	Consulta de actos certificados
tests_restituir.py	21	Restituição (hv3)
tests_intake.py / tests_custody_v2.py	20 / 20	Recepção; custódia v2
(restantes 27 ficheiros)	—	Taxonomia, integridade, auditoria, instituições, etc.

Tabela 9: Distribuição (parcial) dos métodos de teste da *suite core/*.

4.3 Verificação dos critérios de aceitação

Cada objectivo F1–F6 (§1.5) tem cobertura de teste correspondente:

- **F1 (autenticação).** Um *login* válido devolve *cookies* HttpOnly; credenciais inválidas devolvem 401 sem fuga de informação; *throttle* de 5/min activa-se sob força bruta (tests_api.py).
- **F2 (registo com *hash*).** A criação calcula *integrity_hash*; alterar os *bytes* da foto (mantendo o nome) invalida o *hash*; o *hash* é invariante à remoção de EXIF (tests_image_processing.py, tests_coverage.py).
- **F3 (*ledger*).** A génese é obrigatória, única e coerente com a proveniência; transições inválidas são recusadas com a mensagem legal; o estado legal derivado coincide com o esperado em cenários não-lineares; após terminal nenhum evento é aceite (tests_policy_custody_transitions.py, tests_validar.py, tests_despacho.py, tests_restituir.py).
- **F4–F6.** Ficha digital por tipo; *endpoints* REST documentados; PDF com QR cujo *hash* é verificável no *endpoint* público (tests_guia.py, tests_public_verify.py).

4.4 Exemplos de funcionamento normal

Para além da verificação automática, as figuras seguintes documentam o funcionamento normal da aplicação em produção (dados fictícios da instância de demonstração), ligando cada critério de aceitação à respectiva evidência visual.

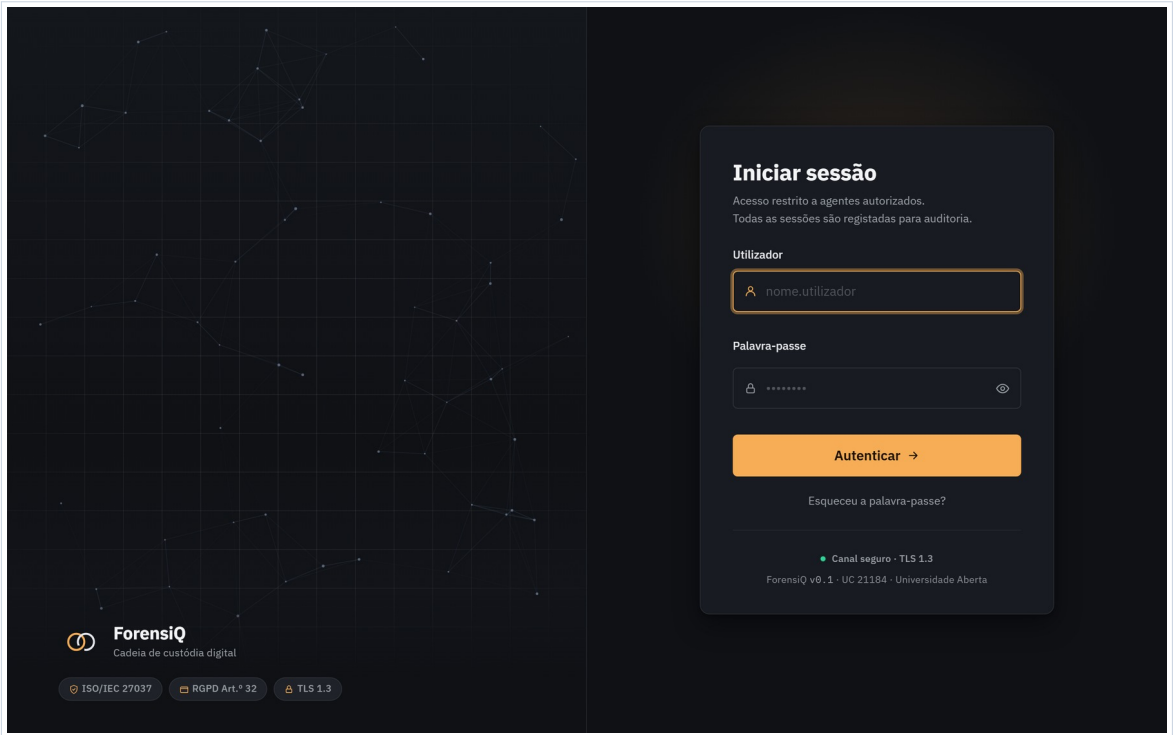


Figura 13: Autenticação (F1): ecrã de *login* sobre TLS 1.3; credenciais válidas devolvem *cookies* JWT HttpOnly e redireccionam para o painel, com aviso de que as sessões são registadas para auditoria.

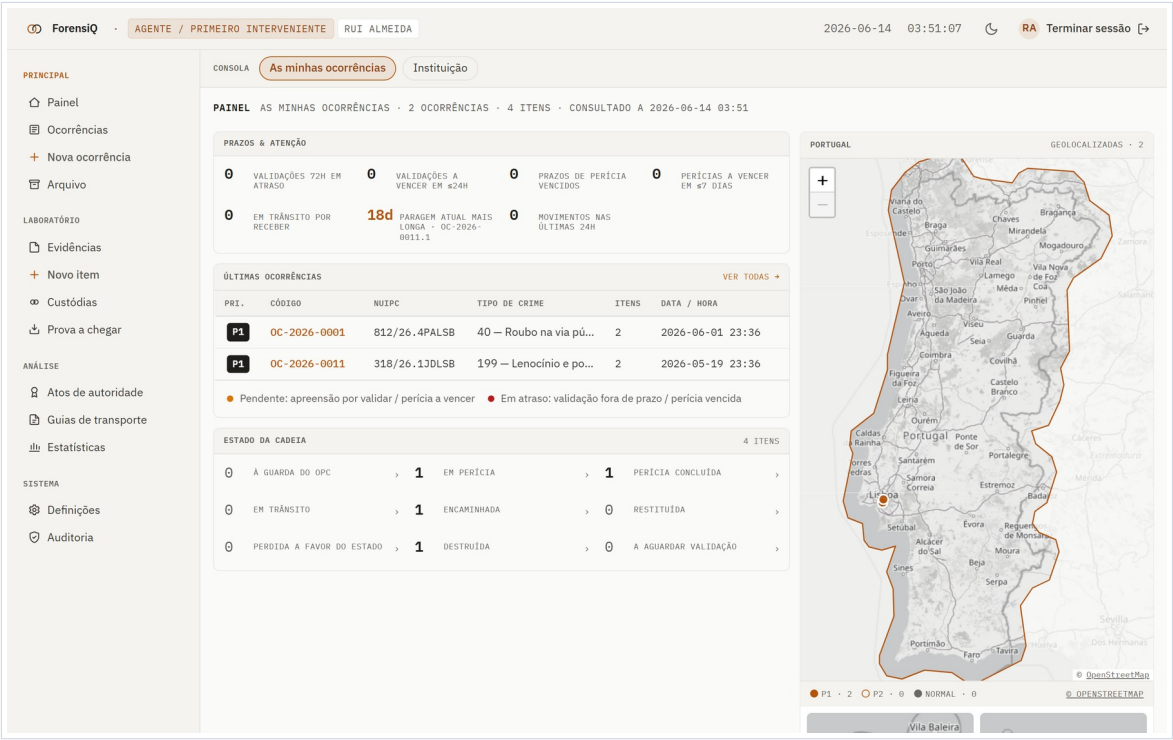


Figura 14: Painel pós-autenticação de uma conta de agente (*primeiro interveniente*): lista “As minhas ocorrências” com indicadores de prazos e atenção, últimas ocorrências por NUIPC e mapa do percurso por item; a barra superior identifica a função e disponibiliza o termo de sessão. Dados fictícios da instância de demonstração.

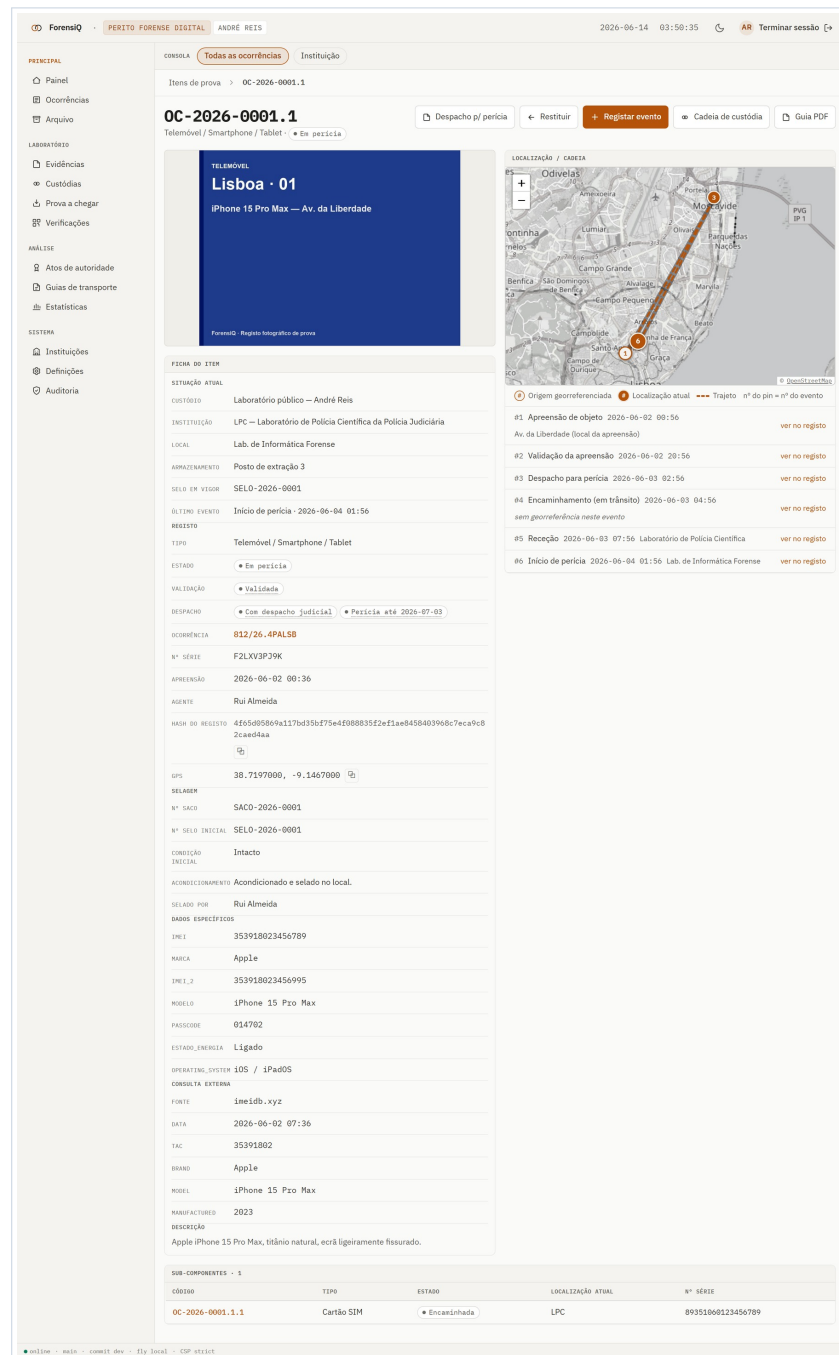


Figura 15: Ficha digital da evidência (F2/F4): atributos por tipo (`type_specific_data`), *hash* SHA-256 de integridade, coordenadas GPS e *timestamp* do servidor, com a *timeline* de custódia e o mapa à direita. Captura em formato retrato (vista completa da ficha).

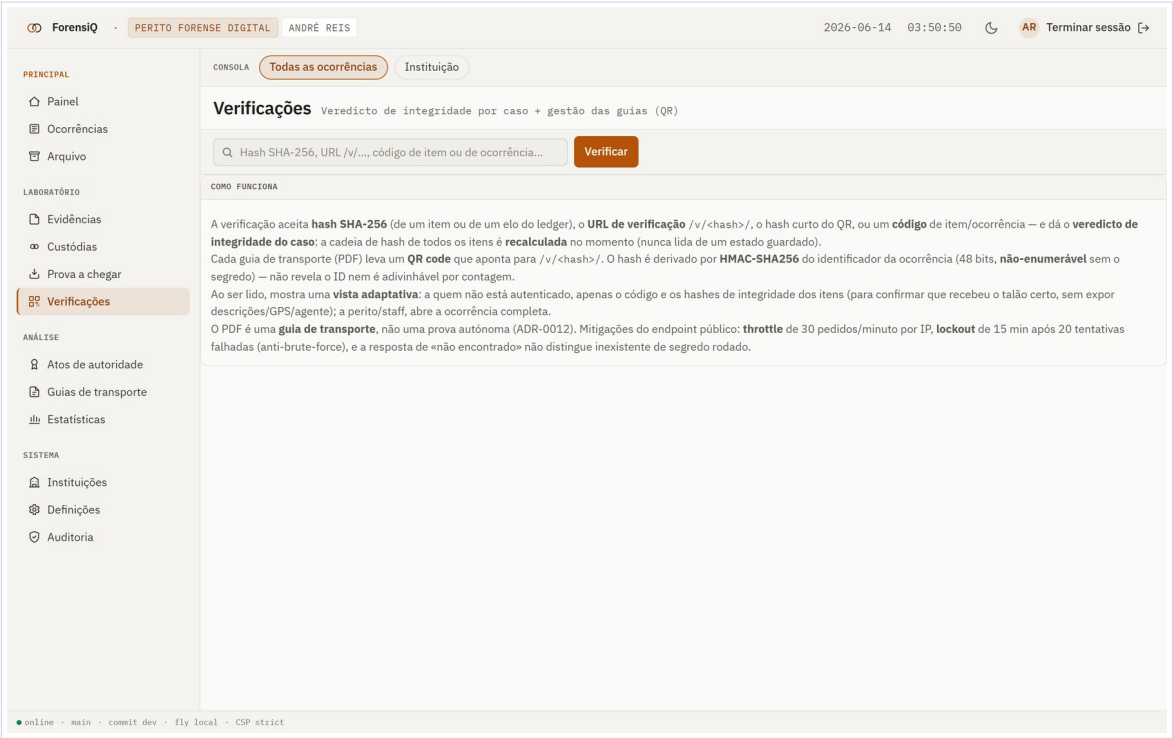


Figura 16: Verificação de integridade (F6): a consola recalcula a cadeia de *hashes* de um item a partir dos campos públicos relidos e expõe a verificação pública (*/v/<hash>/*) acessível por QR, sem sessão.

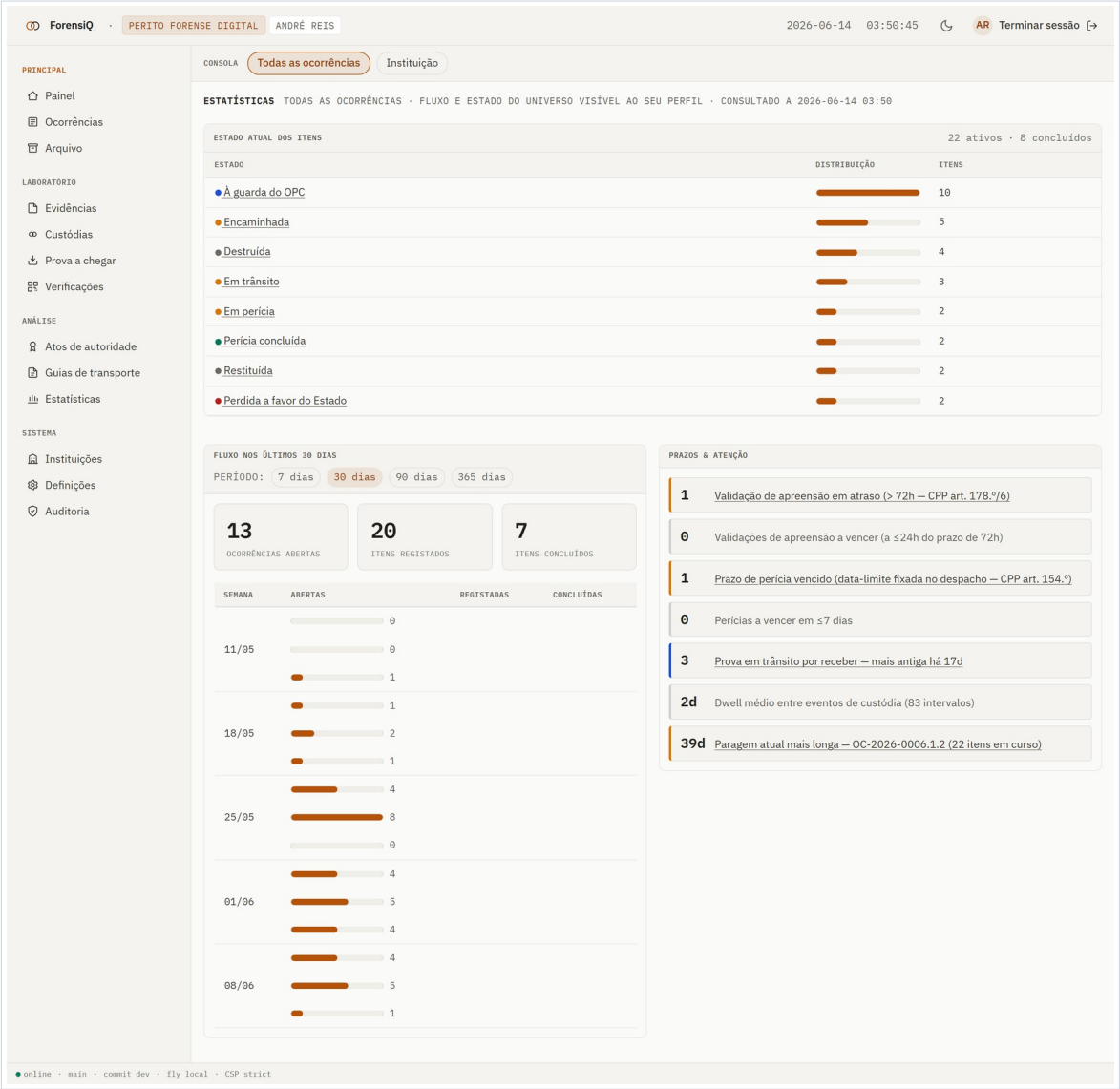


Figura 17: Painel de estatísticas (RF08/RF12): distribuição dos itens por estado de custódia derivado e indicadores de prazos e atenção (validação em atraso, perícias a vencer, *dwell* médio).

4.5 Testes de segurança

A postura de segurança é exercitada por testes dedicados: **IDOR** — o agente A não acede a dados do agente B (listas filtradas, detalhe 403/404), enquanto o perito tem visibilidade por dever (`AuthorizationIDORTest`); **imutabilidade** — PUT/PATCH/DELETE sobre evidências e custódia devolvem 405, e os dados persistem inalterados; **CSP** — `test_no_csp_violations` confirma zero violações de *inline style* em todas as páginas (a auditoria E2E de 2 jun apanhou e corrigiu uma violação causada pela injeção automática de `<style>` pelo HTMX); **throttle** — limites por *scope* (IMEI, geocoding, autenticação) activam-se sob carga; **actos certificados** — a identidade da autoridade é obrigatória nos actos certificados e recusada como “órfã” nos restantes eventos.

4.6 Testes E2E, acessibilidade e rapidez

A camada E2E (Playwright) cobre os fluxos que nenhum teste de unidade alcança: *login* real e *cookie* JWT, criação de ocorrência e evidência, captura de GPS, *upload* de fotografia, *timeline* de custódia, actos em modal, listas com paginação, navegação por teclado e *viewport* móvel. A acessibilidade é validada com *axe-core* em **tema claro e escuro**: a auditoria de 2 jun revelou falhas de contraste WCAG AA (12–25 nós por página, em ambos os temas) que foram corrigidas ao nível dos *tokens* de cor, sem alterar a estrutura nem a densidade. O *Lighthouse*, executado contra a instância HTTPS de produção (20 jun, *headless*), confirmou a rapidez de laboratório das páginas principais (*login*, painel, ocorrências, evidências e estatísticas): pontuação de *performance* entre **93 e 99/100** e de acessibilidade entre **97 e 100/100**, com LCP de 1,7–2,6 s e deslocamento de *layout* (CLS) nulo. Os relatórios (HTML e JSON) ficam em `docs/testing/reports/lighthouse/`. A primeira execução completa da camada E2E (2 jun) registou 28 testes verdes em ≈ 70 s; a *suite* cresceu desde então para 38.

4.7 Cobertura e integração contínua

A cobertura é medida por `coverage.py` com um *gate* de CI a **80%**; a concentração da cobertura está, por desenho, nas áreas críticas para a integridade forense (`models.py`, política, `views.py`, `core/documents/`). A percentagem global da versão final, medida com `coverage` sobre `core` e `forensiq_project`, é de **90,90%**, bem acima do *gate* de 80%.²

A cobertura de linhas mede extensão, não qualidade: por isso os caminhos críticos para a integridade — *triggers* de imutabilidade, encadeamento de *hash* e derivação de estado — são exercitados por testes comportamentais dedicados contra PostgreSQL real (incluindo casos-limite e tentativas de violação), e não apenas *atravessados* pela execução.

O *pipeline* GitHub Actions corre *lint* (`ruff check`; `black` configurado para uso local), a *suite* `core/` completa contra um serviço PostgreSQL (incluindo os *triggers* de imutabilidade, exercitados de facto sobre a base de dados real) e o *gate* de cobertura a cada *push*. As mensagens de *commit* seguem *Conventional Commits* (Conventional Commits Working Group, 2024).

²Medição contra PostgreSQL (`coverage run -source=core,forensiq_project -m pytest`). No intercalar (6 mai) a cobertura era de 71,5%; o *gate* foi elevado para 80% na Fase B.

Nota de reprodutibilidade

Para reproduzir os resultados localmente (Python 3.12+): `pip install -r requirements.txt -r requirements-dev.txt; pytest (suite core/); pytest e2e/-ds=forensiq_project.e2e_settings` (E2E, após `python -m playwright install chromium`). O número exacto de testes recolhidos e a percentagem de cobertura ficam assim confirmados.

5 Conclusões

5.1 Resultados face aos objectivos

O ForensiQ cumpriu o objectivo geral: é uma plataforma *web mobile-first*, em produção em forensiq.pt, que digitaliza o registo, a preservação e a transferência de prova digital pelos *first responders*, com integridade verificável conforme a ISO/IEC 27037:2012. Os seis objectivos específicos F1–F6 foram atingidos e verificados por teste (§4.3); todos os requisitos *Must* e *Should* estão cumpridos, e três *Could have* (funções adicionais, verificação de IMEI e despachos judiciais) foram concretizados para além do previsto na proposta.

A contribuição técnica mais relevante não é uma funcionalidade isolada, mas a *coerência* do modelo de integridade e custódia: um *ledger* de eventos *append-only* cujo estado legal é *derivado* (não persistido), com actos jurídicos selados criptograficamente (*hash* v4) e regras processuais concentradas numa fonte única e testável sem ORM. Esta arquitectura traduz fielmente o processo penal (apreensão, validação, perícia, restituição) num sistema verificável por terceiros.

Síntese quantitativa. O cumprimento dos objectivos traduz-se em indicadores objectivos e verificáveis, sintetizados na Tabela 10. A *suite* automatizada conta 955 testes de unidade e integração (todos aprovados contra PostgreSQL, nenhum ignorado) e 38 testes *end-to-end*, com cobertura de linhas de 90,90% — bem acima do *gate* de 80% imposto em integração contínua. A conformidade com a ISO/IEC 27037:2012 está rastreada numa matriz de doze controlos, todos no estado *implementado* (Anexo A), e a postura de segurança de transporte (TLS e cabeçalhos HTTP) foi confirmada por três verificações externas automáticas (Anexo B). As dezanove decisões de arquitectura estão registadas em ADR, com as alternativas consideradas.

5.2 Dificuldades e limitações

Em coerência com o princípio do Guia — limitações conhecidas e bem explicadas são preferíveis à ausência aparente de limitações — registam-se as seguintes:

1. **Modelo de integridade sem âncora externa.** O *hash* é SHA-256 sobre campos públicos (não-HMAC). Um adversário com privilégios DBA poderia desactivar *triggers*, alterar registos e recomputar a cadeia internamente; a detecção exige uma âncora externa anterior (exportação assinada ou selo TSA RFC 3161), que é trabalho futuro. O controlo de acesso ao motor é, assim, uma premissa organizacional explícita.

Indicador	Resultado (24 jun 2026)
Objectivos específicos F1–F6	6/6 cumpridos e verificados por teste
Requisitos <i>Must</i> / <i>Should</i>	100% cumpridos
Requisitos <i>Could have</i> (RF10–RF13)	4/4 cumpridos (3 além da proposta)
Testes de unidade e integração	955 (todos aprovados, PostgreSQL)
Testes <i>end-to-end</i>	38
Cobertura de linhas (<i>gate</i> CI a 80%)	90,90%
Decisões de arquitectura (ADR)	19
Matriz de conformidade ISO/IEC 27037	12 controlos, todos implementados
Verificações externas (TLS/cabeçalhos)	Qualys SSL Labs A+; Mozilla Observatory A+; HSTS <i>preload</i> activo

Tabela 10: Balanço quantitativo do ForensiQ à data da entrega final.

- RGPD Art. 32, alíneas c) e d).** O restabelecimento de acesso assenta em PITR (Neon) e volume (Fly) sem exercício formal de RTO/RPO; a avaliação regular automatizada está parcialmente coberta (SAST e SCA já em CI via `security.yml` — *bandit*, *pip-audit* e *trivy* —, faltando *DAST* em CI e *pentest* externo). O sistema não está em condições de operar com dados reais sem endereçar estas lacunas.
- Operação *offline*.** O registo exige ligação activa no momento da submissão: embora exista um *Service Worker* que faz *precache* da casca (PWA instalável), este ignora deliberadamente os *endpoints* de prova e dados mutáveis (`/api`, `/media`, `/v/`, `/pdf`) por imutabilidade forense, pelo que não há fila local de submissões assinadas nem sincronização diferida.
- Geração de PDF síncrona.** A exportação é síncrona; sob carga elevada beneficiaria de processamento assíncrono (Celery/RQ).
- Concentração de *commits* na recta final.** A Fase 2/3 concentrou actividade em Junho (risco R07 materializado); mitigado por cadência regular, *branches* e *Conventional Commits*, mas reconhecido.
- Superfície de defesa alargada.** As dezanove decisões de arquitectura e as seis funções aumentam o que tem de ser defendido oralmente; a maioria dessas decisões está, por isso, documentada em ADR com as alternativas consideradas.

5.3 Trabalho futuro

As prioridades de evolução, por ordem de valor, são: (i) âncora externa de integridade (exportações assinadas e/ou selo TSA), fechando o modelo de ameaças face ao adversário DBA; (ii) evolução do PWA-casca já existente (manifesto + *service worker* com *precache* da casca) com uma fila local de submissões assinadas e sincronização em segundo plano, para apreensão sem cobertura; (iii) *DAST* automatizado em *pipeline* e *pentest* externo, com exercício formal de RTO/RPO, para prontidão RGPD; (iv) exportação de PDF assíncrona; (v) módulos forenses adicionais (biológico, químico) sobre a arquitectura de extensibilidade já desenhada (ADR-0006); e (vi) integração com sistemas internos da PSP, quando as autorizações o permitirem.

5.4 Reflexão final

O percurso do projecto ilustra uma lição de engenharia que o autor considera a mais valiosa: reconhecer um modelo inadequado a tempo e *corrigi-lo* vale mais do que defendê-lo. A máquina de estados linear do intercalar era defensável como simplificação de MVP, mas não era fiel ao processo; documentar essa fragilidade no intercalar e substituí-la por um *ledger* de eventos na fase final foi a decisão estruturante do projecto. O resultado é um sistema cuja arquitectura o autor compreende e consegue defender em cada decisão — que é, precisamente, o critério da defesa pública. O ForensiQ não é um protótipo que “funciona até encontrar um caso não previsto”: é uma base sólida, com limitações honestamente delimitadas, sobre a qual um sistema de produção real para a PSP poderia ser construído.

Uso de IA generativa

Em cumprimento da secção 8 do *Guia de Projecto* (Pestana, 2026), regista-se, com transparência, o recurso a ferramentas de *IA generativa* como *apoio* ao desenvolvimento do ForensiQ. A concepção do sistema, as decisões de arquitectura, a interpretação dos requisitos e a redacção deste relatório são da autoria e da responsabilidade exclusivas do autor; as ferramentas de IA foram um instrumento auxiliar, sempre subordinado à sua direcção, ao seu juízo e à sua validação.

Autoria e responsabilidade. As decisões estruturantes do projecto — o *ledger* de eventos (ADR-0015), o modelo de seis funções com credencial e instituições (ADR-0017), a identificação hierárquica da prova (ADR-0016), a fórmula de *hash* encadeado (ADR-0013) e a concentração da política numa fonte única (ADR-0019) — foram tomadas, compreendidas e fundamentadas pelo autor, e estão registadas nos dezanove ADRs com as alternativas consideradas. Nenhum excerto de código entrou no repositório sem ser lido, compreendido e adaptado pelo autor, que responde por cada linha do sistema e por cada afirmação deste relatório em sede de defesa pública.

Âmbito do apoio de IA. O *Claude* (Anthropic), via *Claude Code* (CLI), foi usado de forma dirigida como assistente em tarefas delimitadas: geração de *boilerplate* (*models*, *serializers*, *viewsets*) posteriormente revisto e adaptado; sugestão de testes a partir de especificações do autor, com validação manual dos *edge cases*; interlocução para confrontar alternativas de arquitectura, cuja decisão final foi sempre do autor; e revisão de redacção, de coerência terminológica e apoio à reconciliação documental deste relatório, sempre validados pelo autor. Pontualmente, recorreu-se ainda ao *GitHub Copilot* (sugestões *inline*) e ao *ChatGPT* (exemplos de *packages* LaTeX).

Fronteiras do uso. O recurso a IA **não** se estendeu à tomada de decisões de âmbito, à interpretação dos requisitos do orientador, à validação dos critérios de aceitação, nem à produção de qualquer afirmação técnica que o autor não consiga defender. Não foi usada IA no encadeamento criptográfico (SHA-256) dos registos nem na auditoria externa independente

(Qualys SSL Labs, Mozilla Observatory, HSTS Preload), que são serviços auditáveis por terceiros. A reconciliação documental da recta final foi assistida por IA, com revisão e validação integral do autor.

A Matriz de conformidade ISO/IEC 27037:2012

A Tabela 11 apresenta a matriz de rastreabilidade entre os requisitos da norma ISO/IEC 27037:2012 (ISO/IEC, 2012) e os mecanismos implementados na versão final do ForensiQ. Cada controlo é ancorado no ficheiro de produção que o materializa e, quando aplicável, nas listagens de código do Capítulo 3 (§3.3), verificadas linha a linha contra o repositório. Esta matriz reflecte a arquitectura *tal como foi construída* — o *ledger* de eventos, as seis funções e a remoção do modelo `DigitalDevice` —, actualizando a versão anterior ao *refactor* guardada em `docs/scope/iso27037-traceability.pdf`.

Secção	Princípio da norma	Implementação no ForensiQ
§5.2	Princípios da prova digital; integridade	Controlo de acesso por seis funções com credencial e instituições (ADR-0017); JWT em <code>cookies</code> <code>HttpOnly</code> + <code>Secure</code> + <code>SameSite</code> com rotação de <code>refresh</code> ; <code>AuditLog</code> transversal com <code>correlation_id</code> por pedido.
§5.4.2	Identificação de prova digital	Modelo <code>Evidence</code> com 18 tipos <i>digital-first</i> (ADR-0010); campos obrigatórios (descrição, série, GPS, <i>timestamp</i>) validados em <code>Evidence.clean</code> ; identificador legível <code>ITM-AAAA-NNNNN</code> gerado em transacção atómica com retentativa.
§5.4.3–5.4.4	Recolha e aquisição (acto <i>documentado</i> , não realizado)	O ForensiQ documenta o acto de recolha — que ocorre fora do sistema, a jusante do qual se posiciona —, não o executa: registo fotográfico obrigatório (validação de tamanho e tipo); georreferenciação via <i>Geolocation API</i> no <i>wizard</i> ; <i>timestamps</i> sempre do servidor (<code>timezone.now()</code> , NTP), nunca do cliente. O <code>acquisition_hash</code> (casos <i>live</i>) é um valor <i>externo</i> , fornecido pela ferramenta de aquisição de terceiros e carimbado na génese; o sistema incorpora-o no encadeamento mas não o calcula sobre os <i>bytes</i> adquiridos.
§5.4.5, §6.9	Preservação de integridade	<i>Hash</i> SHA-256 encadeado e puro (<code>compute_record_hash</code> , Listagem 1); imutabilidade em três camadas — ORM (<code>AppendOnlyModel</code> , Listagem 3), API (<i>viewsets</i> só de leitura/criação) e <i>triggers</i> PostgreSQL BEFORE UPDATE/DELETE (Listagem 4).

Secção	Princípio da norma	Implementação no ForensiQ
§6.1	Cadeia de custódia	<code>ChainOfCustody</code> <i>append-only</i> (<i>ledger</i> de eventos, ADR-0015); estado legal <i>derivado</i> da sequência (<code>derive_legal_state</code> , Listagem 5); ordem canónica por <code>sequence</code> + <code>UniqueConstraint(evidence, sequence)</code> e escrita serializada com <code>transaction.atomic</code> + <code>select_for_update</code> (Listagem 2); guardas de transição numa fonte única (ADR-0019).
§6.3–6.4	Funções, responsabilidades e competência	Modelo de seis funções (ADR-0017) com <i>permission classes</i> dedicadas e <i>need-to-know</i> ; filtragem por <code>request.user</code> ao nível do <code>get_queryset()</code> de cada <i>viewset</i> ; só-leitura aplicado no <i>render</i> e na API.
§6.6, §6.9.4	Documentação do processo e do transporte	Geração automática de PDF forense (ocorrência e item) e guia de transporte com QR (ADR-0012, <code>core/documents/guia_transporte.py</code>), com declaração ISO/IEC 27037 incorporada; exportação CSV auditada.
§7.1	Dispositivos e periféricos (atributos)	Atributos técnicos (tipo, marca, modelo, estado, série, IMEI validado por algoritmo de Luhn) associados à <i>Evidence</i> via taxonomia <i>digital-first</i> e <code>type_specific_data</code> (ADR-0010; o modelo <code>DigitalDevice</code> foi removido).
§7.1	Suportes de armazenamento digital	Taxonomia inclui <code>STORAGE_MEDIA</code> , <code>INTERNAL_DRIVE</code> , <code>MEMORY_CARD</code> , <code>SIM_CARD</code> , <code>RFID_NFC_CARD</code> e <code>DIGITAL_FILE</code> ; campos específicos (IMEI, IMSI, ICCID, MAC, VIN) em <code>type_specific_data</code> (JSON) com serialização determinística.
§5.3.2	Auditabilidade	<code>AuditLog</code> regista <code>user</code> , <code>action</code> (<code>VIEW/CREATE/EXPORT_PDF/EXPORT_CSV</code>), <code>resource_type/id</code> , <code>ip_address</code> , <code>correlation_id</code> e <i>timestamp</i> do servidor, com índices compostos para auditoria eficiente.
Transversal	Segurança da infra-estrutura	HSTS de um ano com <code>includeSubDomains</code> e <code>preload</code> ; CSP <i>nonce-based</i> (sem <code>unsafe-inline</code>); <code>Referrer-Policy: strict-origin-when-cross-origin</code> (ADR-0007); <i>rate-limiting</i> DRF; paginação obrigatória. Validação externa no Anexo B.
Transversal	Protecção contra IDOR	<code>get_queryset()</code> filtra por função (<i>need-to-know</i>); <code>IsOwnerOrReadOnly</code> valida <i>ownership</i> nas escritas; testes <code>AuthorizationIDORTest</code> exercitam o acesso cruzado agente A vs. agente B, com rejeição por 404 (para evitar enumeração).

Secção	Princípio da norma	Implementação no ForensiQ
--------	--------------------	---------------------------

Tabela 11: Matriz de rastreabilidade ISO/IEC 27037:2012, alinhada ao código final (todos os controlos no estado *implementado*); a numeração de secção segue a estrutura de cláusulas da norma. As três linhas marcadas *Transversal* são controlos adicionais do ForensiQ que reforçam a postura de segurança sem corresponder a uma cláusula numerada da norma. Actualiza docs/scope/iso27037-traceability.pdf, que descrevia a arquitectura anterior ao refactor (ADR-0014 a 0019).

Âmbito da conformidade

O ForensiQ **não** é um sistema certificado ISO/IEC 27037; implementa os princípios e os controlos previstos na norma. As lacunas para um *deployment* com dados reais — cifra de *media* em repouso, *backup* automatizado de *media* e *pentest* externo formal — estão registadas em docs/compliance/rgpd-art32-checklist.md e enquadradas como trabalho futuro (§5.3).

B Verificações externas de postura TLS e de cabeçalhos HTTP

A postura de segurança da instância de produção (<https://forensiq.pt>) foi submetida a três serviços externos independentes a 18 de Abril de 2026. Os relatórios originais estão guardados em docs/compliance/external-tests/ e são reproduzíveis a partir das URLs da Tabela 12.

Serviço	Resultado	URL de reprodução
Mozilla HTTP Observatory	A+	https://developer.mozilla.org/en-US/observatory/analyze?host=forensiq.pt
Qualys SSL Labs	A+	https://www.ssllabs.com/ssltest/analyze.html?d=forensiq.pt
HSTS Preload (Chromium / Mozilla / Edge / Apple)	Domínio incluído na lista pré-carregada (<i>preloaded</i>)	https://hstspreload.org/?domain=forensiq.pt

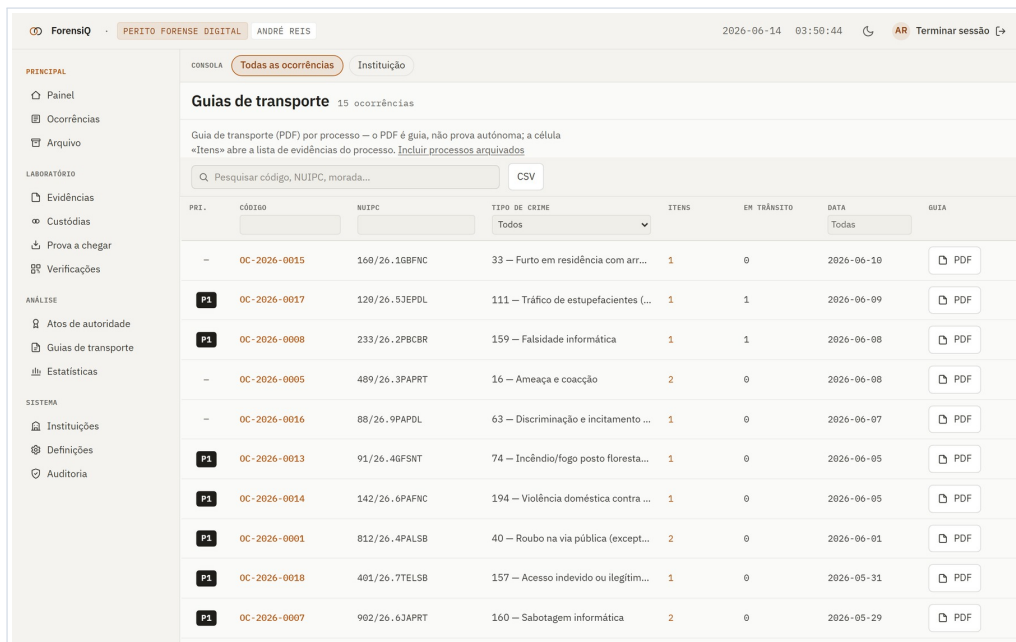
Tabela 12: Resultados das auditorias externas de segurança (18 abr 2026); PDFs originais em docs/compliance/external-tests/.

O Mozilla HTTP Observatory avalia os cabeçalhos de segurança HTTP (CSP, HSTS, *Referrer-Policy*, *X-Content-Type-Options*) e atribuiu pontuação **A+**; o Qualys SSL Labs avalia a configuração TLS (TLS 1.2/1.3, ECDHE, HSTS, OCSP *stapling*) e atribuiu grau **A+**. A inclusão do domínio na lista *HSTS preload* — partilhada por Chromium, Mozilla, Edge e Apple — garante HTTPS estrito mesmo no primeiro acesso, propriedade relevante para um sistema que faz circular prova judicial. Trata-se, em todo o caso, de verificações automáticas da postura de transporte e de cabeçalhos, não de uma auditoria de segurança aplicacional (*DAST/pentest*). Recomenda-se a reexecução trimestral ou após qualquer alteração à configuração TLS ou aos cabeçalhos de segurança.

C Exemplo do guia de transporte em PDF

O ForensiQ gera, em tempo de execução, guias de transporte em PDF que acompanham a prova em trânsito, cada uma com um código QR que remete para a verificação pública da remessa (`/v/g/<token>`). A decisão de desenho está registada na ADR-0012 e a geração é feita pelo módulo `core/documents/guia_transporte.py` (ReportLab). A Figura 18 mostra a vista `/reports/` a partir da qual a guia é exportada na instância de demonstração; a Figura 19 reproduz uma guia efectivamente gerada pela aplicação (remessa GT-2026-0004).

O exemplar em PDF é produzido em *runtime* e não se encontra versionado no repositório, por opção de desenho: a guia é um documento de transporte e não a prova — o valor probatório reside na cadeia de custódia e no encadeamento de *hashes*, não no papel. A verificação pública por QR (da remessa em `/v/g/<token>` e de cada item em `/v/<hash>/`) é, além da entrada, a única superfície sem sessão, e recalcula a integridade da cadeia do item a partir dos campos públicos do registo.



PRI.	CÓDIGO	NUIPC	TIPO DE CRIME	ITENS	EM TRÂNSITO	DATA	GUIA
—	OC-2026-0015	168/26.1GBFNC	33 — Furto em residência com arr...	1	0	2026-06-10	PDF
P1	OC-2026-0017	120/26.53EPDL	111 — Tráfico de estupefacientes (...)	1	1	2026-06-09	PDF
P1	OC-2026-0008	233/26.2PBCBR	159 — Falsidade informática	1	1	2026-06-08	PDF
—	OC-2026-0005	489/26.3PAPRT	16 — Ameaça e coacção	2	0	2026-06-08	PDF
—	OC-2026-0016	88/26.9PAPDL	63 — Discriminação e incitamento ...	1	0	2026-06-07	PDF
P1	OC-2026-0013	91/26.4GFSNT	74 — Incêndio/fogo posto floresta...	1	0	2026-06-05	PDF
P1	OC-2026-0014	142/26.6PAFNC	194 — Violência doméstica contra ...	1	0	2026-06-05	PDF
P1	OC-2026-0001	812/26.4PALS	40 — Roubo na via pública (except...	2	0	2026-06-01	PDF
P1	OC-2026-0018	401/26.7TELS	157 — Acesso indevido ou ilegítim...	1	0	2026-05-31	PDF
P1	OC-2026-0007	902/26.63APRT	160 — Sabotagem informática	2	0	2026-05-29	PDF

Figura 18: Vista `/reports/` a partir da qual as guias de transporte são exportadas (dados fictícios da instância de demonstração).

GUIA DE TRANSPORTE	
Nº GT-2026-0004 - ISO/IEC 27037 emitido por ForensIQ	
	
Verifique em forensiq.pt/vig905259905b74	
REMESSA	
DE PSP-LSB	PARA LPC
ENVIADO 14/06/2026 15:16	PORTADOR Sérgio Abreu - PSP-FNC-905
REMETENTE Rui Almeida	
ITENS TRANSPORTADOS (1)	
OC-2026-0019.1 - CCTV / DVR / NVR Marca / Fabricante Huawei - Modelo ASD-93kfwle	
PROCESSO	
NUIPC 7/26.3AMOTE - Furtos em residência com arrombamento, escalamento ou chaves falsas - Normal	
PERCURSO	
OC-2026-0019.1 PSP-LSB (em trânsito) LPC	

Figura 19: Guia de transporte em PDF gerada pela aplicação (remessa GT-2026-0004): remessa (de/para, portador, remetente), itens transportados, processo (NUIPC) e percurso por item, com QR para a verificação pública (/v/g/<token>). Excerto da página; dados fictícios.

Referências

- Association of Chief Police Officers (2012). Good practice guide for digital evidence. Technical report, ACPO. Version 5.
- Aumasson, J.-P., Neves, S., Wilcox-O’Hearn, Z., and Winnerlein, C. (2013). BLAKE2: Simpler, smaller, fast as MD5. In *Applied Cryptography and Network Security (ACNS 2013)*, pages 119–135. Springer.
- Bertoni, G., Daemen, J., Peeters, M., and Van Assche, G. (2011). The Keccak reference. Submission to the NIST SHA-3 competition (Round 3). Selected as SHA-3 (FIPS 202).
- Brown, S. (2014). *Software Architecture for Developers*. Leanpub.
- Brown, S. (2024). The C4 model for visualising software architecture. <https://c4model.com>.
- Casey, E. (2011). *Digital Evidence and Computer Crime: Forensic Science, Computers and the Internet*. Academic Press, 3 edition.
- Conventional Commits Working Group (2024). Conventional commits 1.0.0. <https://www.conventionalcommits.org/>.
- European Network of Forensic Science Institutes (2015). Best practice manual for the forensic examination of digital technology. ENFSI-BPM-FIT-01. Version 01, Novembro de 2015.
- Fowler, M. (2012). TestPyramid. <https://martinfowler.com/bliki/TestPyramid.html>.
- Hodges, J., Jackson, C., and Barth, A. (2012). HTTP strict transport security (HSTS). RFC 6797, IETF.
- ISO/IEC (2012). Information technology — security techniques — guidelines for identification, collection, acquisition and preservation of digital evidence. ISO/IEC 27037:2012. International Organization for Standardization.
- Kent, K., Chevalier, S., Grance, T., and Dang, H. (2006). Guide to integrating forensic techniques into incident response. Technical Report SP 800-86, National Institute of Standards and Technology.
- Nakamoto, S. (2008). Bitcoin: A peer-to-peer electronic cash system. <https://bitcoin.org/bitcoin.pdf>.
- National Institute of Standards and Technology (2015). Secure hash standard (shs). FIPS PUB 180-4.
- OWASP Foundation (2021). OWASP top ten 2021. <https://owasp.org/Top10/>.
- Parlamento Europeu e Conselho da União Europeia (2016). Regulamento (ue) 2016/679 relativo à protecção das pessoas singulares no que diz respeito ao tratamento de dados pessoais e à livre circulação desses dados. Jornal Oficial da União Europeia, L 119.
- Pestana, P. D. (2025). Plataforma modular de captura e preservação de evidência digital para OSINT. Projecto #38 — LEI 2025/26, Universidade Aberta.

- Pestana, P. D. (2026). Guia de projecto de engenharia informática — 2025/26. Versão 4.0, Universidade Aberta.
- Sage, D. (2024). Django REST framework simple JWT. <https://django-rest-framework-simplejwt.readthedocs.io/>.
- Shostack, A. (2014). *Threat Modeling: Designing for Security*. Wiley.
- Stevens, M., Bursztein, E., Karpman, P., Albertini, A., and Markov, Y. (2017). The first collision for full SHA-1. In *Advances in Cryptology — CRYPTO 2017*, pages 570–596. Springer.
- Wang, X. and Yu, H. (2005). How to break MD5 and other hash functions. In *Advances in Cryptology — EUROCRYPT 2005*, pages 19–35. Springer.
- World Wide Web Consortium (2018). Web content accessibility guidelines (WCAG) 2.1. W3C Recommendation.